

BORIS LOCKPICK

Copyright © NYX Offensive Security



BORIS LOCKPICKS

Teknisk Sikkerhetsrevisjon

Av

NYX OFFENSIVE SECURITY

..

Copyright © NYX Offensive Security



Executive Summary

NYX Offensive Security har i oppdrag fullført en utvidet sikkerhets revisjon av webapplikasjonen til **Boris** Lockpicks. Testen blir gjennomført i form av en White Box test der oppdragsgiver har gitt oppdragstaker tilgang til kildekoden. Oppdragsgiver har ikke gitt tilgang til selve maskinen utover selve kildekoden.

Under testfasen så ble det avdekket flere kritiske sårbarheter som **XSS, Local File inclusion** og **SQL injections** som fremtredende på nettsiden. I tillegg det ble også oppdaget en bakdør kjørende på port **42422** under en full **Nmap**- skanning av portene.

Copyright © NYX Offensive Security



Innholdsfortegnelse

Innhold

Executive Summary **3**
Innholdsfortegnelse **4**
Konfidensialitetserklæring **5**
Ansvarsfraskrivelse **5**
Kontakt informasjon **5**
Terminologi **6**
Sammendrag Av Funn **7**
Vurdering av sårbarhet **8**
Metodikk **9**
Pre-Engagement 9
Intelligence-gathering 10
Threat-modeling 12
Vulnerability analysis 12
Exploitation 12
Post-Exploitation 12
Reporting 13
Sårbarhets Oversikt **14**
Verktøy brukt under revisjonen **15**
Tabell over sårbarheter **16**
Funn av sårbarheter **18**
Konklusjon **72**

Copyright © NYX Offensive Security



Konfidensialitetserklæring

Innholdet i dokumentet er klassifisert som FORTTROLIG. Dokumentet inneholder beskrivelser av sårbarheter og metoder for å utnytte systemet og sensitiv systeminformasjon. Dersom dette dokumentet kommer på avveie kan ondsinnede aktører misbruke dokumentet.

Ansvarsfraskrivelse

Dette er en rapport utarbeidet av **NYX Offensive Security** som er en del av en autorisert sikkerhetsrevisjon på vegne av kunden Boris Lockpicks.

Formålet for denne revisjonen har vært å finne svakheter i systemene for så å bidra til å stryke oppdragsgivers sikkerhet. Funnene i denne rapporten viser til et øyeblikksbilde av hvordan sikkerhetstilstanden er på dette testtidspunktet. Nye sårbarheter kan oppstå over tid, selv om man ikke har nye funn i enkelte områder garanterer ikke at systemet er fritt for feil.

Kontakt informasjon

Navn	Tittel	Kontakt informasjon
Ola Nordman	Penetrasjons Tester	Tlf: 45787878 Email: Ola@gmail.com

Copyright © NYX Offensive Security



Terminologi

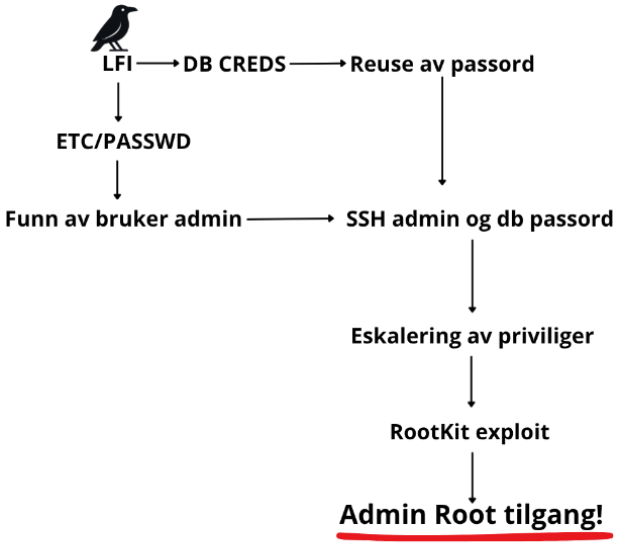
I rapporten blir det brukt begreper som kan være vanskelig å forstå fra en utenforstående uten teknisk kompetanse, denne termologien skal kunne forklare alle begreper og uttrykk som er brukt i rapporten som skal gi leseren en helhetlig forståelse av revisjonen.

Nøkkelord	Beskrivelse
SQL-Injection	Sårbarhet i en input der bruker kan legge inn SQL-spørringer og tilgang til databasen.
Cross-site-scripting (XSS)	Sårbarhet som lar bruker injisere ondsinnet kode på nettleseren.
Stored Cross-site-scripting (XSS)	Lagret XSS er sårbarhet som lar en bruker kjøre vilkårlig kode på webapplikasjonen som server tar imot.
MD5 (Lagring av passord)	Kryptografisk algoritme som passordet er lagret i, skal hindre at angriper eller utviklere kan se brukerens passord. MD5 er lett å knekke og ikke anbefalt å bruke.
Gjenbruk av passord	Bruk av samme passord i andre tjenester. Eksempel kan være database passord blir brukt i SSH
Local file inclusion (LFI)	En sårbarhet som lar en angriper se i filene til server
White Box Test	Type penetrasjon test metode der tester har tilgang til kildekode fra kunden.
Trussel aktør	En person eller gruppe som har intensjon om å utnytte sårbarheter og direkte angripe systemer.
CVSS	Common Vulnerability Scoring System en åpen standard for vurdering av risikoen til en sårbarhet
Clickjacking	Sårbarhet som lar en bruker klikke på et usynlig element på angripers sin side men klikker i realiteten på en annen nettside som bruker har sin konto hos.
ROOT	Høysete privilegiene som kan oppnås på Linux
Bakdør	Skjult program eller metode som omgår sikkerheten til en applikasjon der de som har lagd den bakdøren vet om.
IDOR	Type sårbarhet der det ikke blir tilstrekkelig validert om en bruker har autorisasjon til objektet. F.eks. ved å endre bruker id til en profil og få opp en annen person sin profil.
SSH	Secure Shell nettverksprotokoll som skal gi kryptert måte å styre en annen maskin på.
TLS/SSL	Protokoller som skal sørge for at kommunikasjonen over internett er kryptert.

Copyright © NYX Offensive Security

Sammendrag Av Funn

Ved å koble sammen sårbarhetene som ble funnet kunne **NYX** OFFENSIVE oppnå full tilgang til maskinen. Under kan du se måten dette ble oppnådd på. Den største sårbarheten som gjorde at **NYX** fikk fullt tilgang til hele maskinen som kjører webapplikasjonen var sårbarheten **Local File Inclusion** (**LFI**) Ved hjelp av denne sårbarheten kunne jeg gå igjennom filene som database tilgangen og passordene som er lagret i den. Under videre undersøkelse oppdaget jeg brukere som **Boris** og **Admin** Videre så testet jeg de samme passordene som jeg fant fra database konfigurasjon filen og oppdaget at **Admin** bruker samme passord «**correcthorse**» for koblingen til SSH. Når jeg kom meg inn i maskinen undersøkte jeg om det var mulig å få for høyde priviliger sånn at jeg kan få tilgang til konfigurasjons filer og sensitive filer som krevde **root** priviliger. Ved undersøkelse av **pkexec** versjonen oppdaget jeg at det var en eldre versjon som var sårbar for **rootkit exploit** ved å ta i bruk denne utnyttelsen fikk jeg tilgang til **root**. Det var også en annen enklere måte å få **root** på og det var å bruke kommandoen **«su root»** og bruke det samme passordet «**correcthorse**» som ga meg også **root** tilgang.



Copyright © NYX Offensive Security



Vurdering av sårbarhet

Alvorlighet	CVSS	Beskrivelse
Kritisk	9.0-10.0	Direkte trussel mot systemet. Utnyttelse vil da gi en angriper fullstendig kontroll over systemet
Høy	7.0-8.9	Sårbarhet som er lett å utnytte og som kan føre til tap av data, anbefalt at dette blir utbedret så fort som mulig.
Medium	4.0-6.9	Feil som kan føre til skade på data eller tap, men som krever at priviliger eller koble sammen en eller flere sårbarheter sammen for å utnyttes.
Lav	0.1-3.9	Sårbarhet som krever store ressurser og fører til begrenset skade. Eksempler på dette kan være reflektert XSS eller clickjacking.
Informativ	0	Er ikke direkte risiko, men kan i fremtid bli brukte til angrep mot målet. Det vil si at informasjon av webserver og hva slags versjon den kjører kan bli brukt til etterretning.

Copyright © NYX Offensive Security



Metodikk

Under denne sikkerhetsrevisjonen ble det brukt en strukturert metodikk. Denne revisjonen er bygd på metodikken til **PTES**

- Pre-engagement interactions
- Intelligence-gathering
- Threat-modeling
- Vulnerability analysis
- Exploitation
- Post-exploitation
- Reporting

Pre-Engagement

Testen retter seg mot følgende inngangpunkt:

- IP: 192.168.33.133

Kontraktsregler

Selskapet **NYX** Offensive Security og kunden **Boris** Lockpicks har inngått en avtale, som er signert av begge parter. Avtalen som dekker dette oppdraget, er datert 30.10.25 og dekker perioden 21.11.25

- Test: WhiteBox
- Out of Scope: Open Source Intelligence, Social Engineering

Copyright © NYX Offensive Security

Intelligence-gathering

Siden dette var en **White box-**test, hadde jeg tilgang til kildekoden. Jeg startet med å undersøke webapplikasjonen og deretter navigerte meg rundt som en vanlig bruker. Videre så ble kildekoden analysert der det ble notert sårbarheter knyttet til **PHP**-koden. Kildekoden ble analysert med **VScode** og det ble funnet kode funksjoner som «**Exec**()» og «**Fopen**()» som man må være forsiktig med å bruke i applikasjonen.

Under denne undersøkelsen så ble det tatt i bruk **NMAP**, **ZAP** og **Nikto** for å automatisk skanne sårbarhetene som finnes i webapplikasjonen.

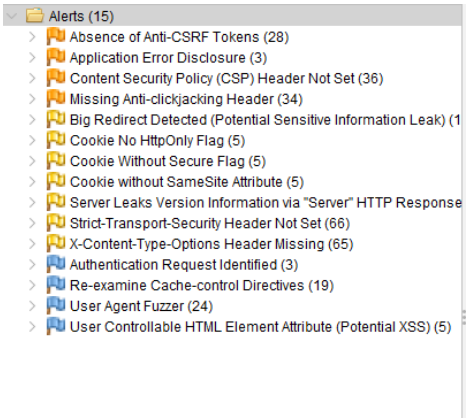
Porter som ble oppdaget

Port	Beskrivelse
22	kjører SSH
80	Kjører HTTP
443	Kjører HTTPS
9999	Kjører Abyss Webserver
42422	Egen utviklet http server (Bakdør)

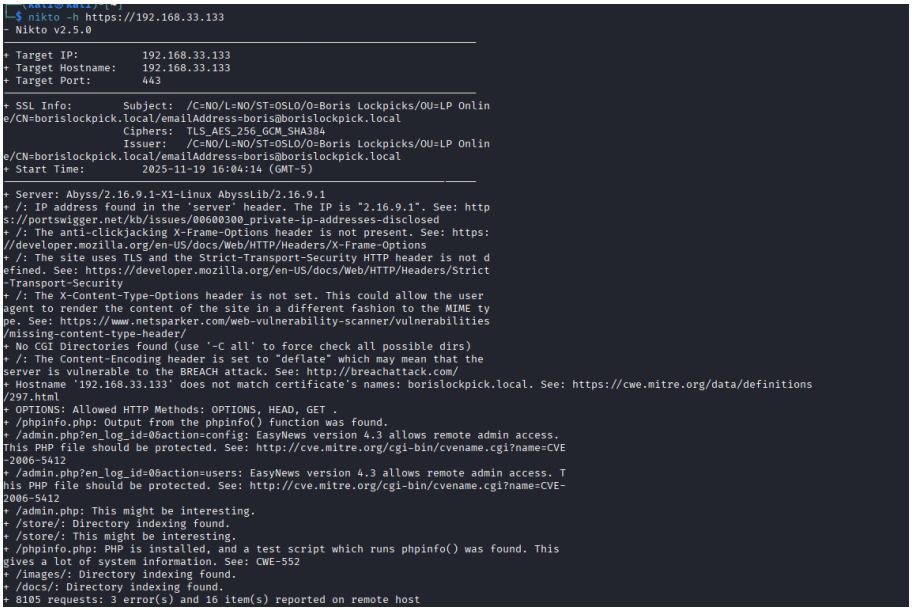
```
PORT      STATE SERVICE  VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u3 (protocol 2.0)
| ssh-hostkey:
|   2048 7e:20:d9:24:45:11:ee:34:77:03:d7:f4:25:c5:95:bb (RSA)
|   256 8f:d1:99:c9:6c:ba:34:de:f2:6a:dc:2b:91:60:61:b5 (ECDSA)
|_  256 fc:ff:40:0e:72:bd:9c:a0:69:dd:69:4a:7e:e3:44:d4 (ED25519)
80/tcp    open  http     Abyss httpd 2.16.9.1-X1 (AbyssLib/2.16.9.1)
|_http-title: Did not follow redirect to https://192.168.33.133/
443/tcp   open  ssl/http Abyss httpd 2.16.9.1-X1 (AbyssLib/2.16.9.1)
| tls-alpn:
|   h2
|_  http/1.1
| tls-nextprotoneg:
|   h2
|_  http/1.1
| ssl-cert: Subject: commonName=borislockpick.local/organizationName=Boris Lo
ckpicks/stateOrProvinceName=OSLO/countryName=NO
| Subject Alternative Name: DNS:borislockpick.local
| Not valid before: 1979-01-01T00:00:00
|_Not valid after:  2029-12-31T23:59:59
|_ssl-date: TLS randomness does not represent time
|_http-title: Boris' Lockpick SEASONSALE
9999/tcp  open  http     Abyss httpd 2.16.9.1-X1 (AbyssLib/2.16.9.1)
| http-auth:
| HTTP/1.1 401 Unauthorized\x0D
|_  Basic Realm=Abyss Web Server Console
|_http-title: Error 401
42422/tcp open  unknown
| fingerprint-strings:
|   DNSVersionBindReqTCP, Help, RPCCheck:
|     HTTP/1.1 400 Bad Request
|     Date: Wed, 19 Nov 2025 06:17:16 GMT
```

Utdrag fra Nmap

Copyright © NYX Offensive Security



Utdrag fra Zap



Utdrag fra Nikto

Copyright © NYX Offensive Security



Threat-modeling

Ved å identifisere de potensielle angrepsvektorene som ble funnet under rekognosering så var det å vurdere truslene ut ifra kildekoden. Her analyserte jeg videre hvordan **SQL** injeksjonen skal utføres på, og hvordan utnyttelse for **LFI** skal sørge for tilgang til systemet.

Vulnerability analysis

Utifra kildekode og de automatiserte skanningene så var neste steget å sørge for at det ikke foreligger en falsk-positiv sårbarhet noe som kan skje med **Nmap** skanningen for eksempel. Her testet jeg om sårbarhetene som **XSS** eller Clickjacking kan valideres og klassifiserte disse etter risiko.

Exploitation

I denne fasen demonstrerer jeg bruken av sårbarhetene som **SQL** injeksjon eller LFI for å hente ut databasen bruke sårbarhetene til å hente ut sensitiv informasjon fra webapplikasjonen. Det er i denne delen man utnytter sårbarhetene på en trygg måte som ikke ødelegger maskinen.

Post-Exploitation

Etter at man har oppnådd tilgang via **LFI** og gjenbruk av passord ble fokuset på å komme seg inn videre i systemet og målet der var å demonstrere muligheten for å skaffe seg tilgang til det høyeste tilgangsnivået som finnes er ROOT. Fra Rekognosering og til Post-exploitation så kan vi danne nå et bilde av hvordan angreps kjeden fungerte.

Angrepskjeden

- **Innsamling:** Sårbarheten **LFI** ble oppdaget
- **Informasjonslekkasje:** Ved å ta i bruk **LFI** til å lese sensitive filer oppdaget jeg klartekst passord som skal gi tilgang til databasen.
- **Tilgang:** Ved å teste det samme passordet som brukes i databasen kunne jeg bekrefte at det gjenbruk av passord blir brukt mellom ulike tjenester som **SSH**
- **Eskalere priviliger:** Ved å ta i bruk **PwnKit** utnyttelsen som jeg fant på github kunne jeg da få full **root** tilgang til maskinen.

Copyright © NYX Offensive Security



Reporting

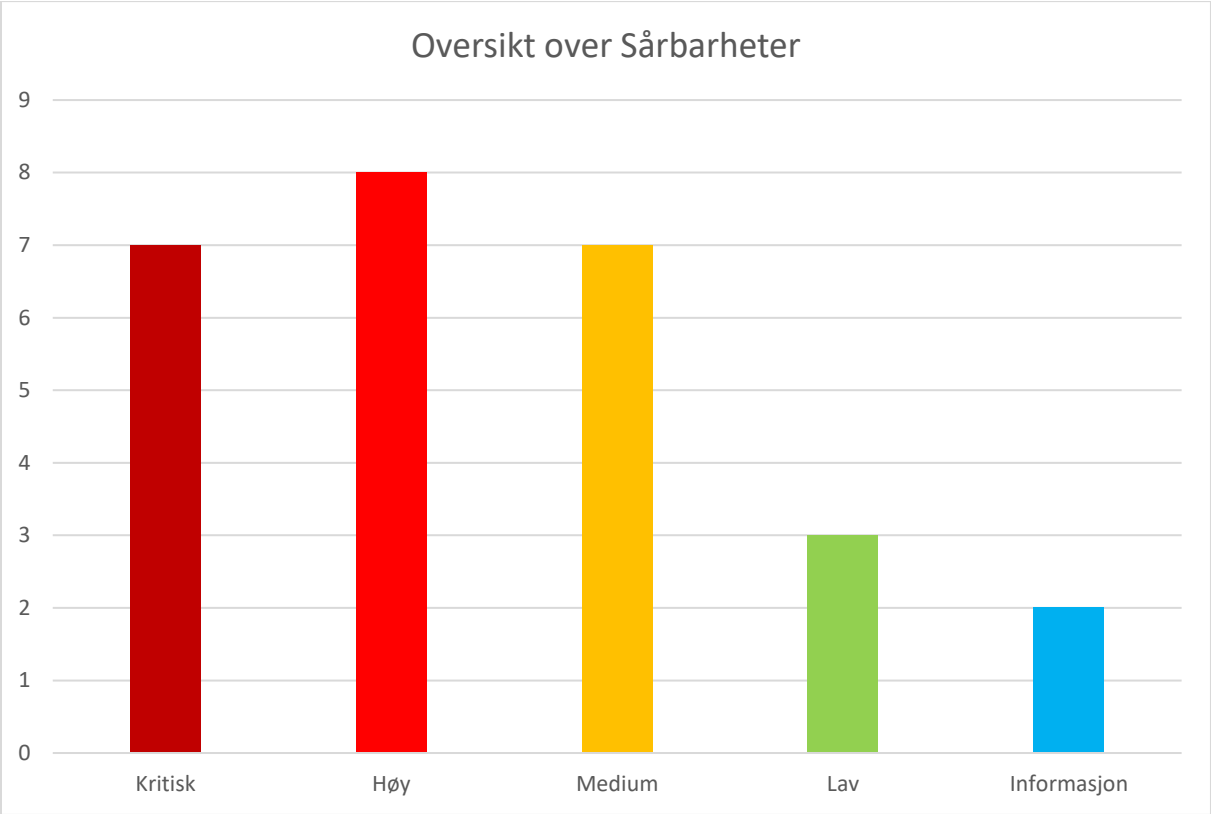
I denne fasen så er alle funn som ble funnet i sikkerhetsrevisjonen dokumentert der målet er å vise til en rapport som fremhever risikoen, funn og utbedring som kunden Boris Lockpics kan utføre. Det er også utarbeidet en liste sårbarheter som krever øyeblikkelig handling fordi dette utgjør en kritisk risiko for systemet og trenger at dette blir fikset så fort så mulig.

Sårbarheter som krever handling	Anbefaling
SQL-injections	Det var flere SQl sårbarheter på webapplikasjonen det anbefales at fikses og har en høyere prioritet.
Local File inclusion	LFI sårbarheten anbefales at det blir fikset på webapplikasjonen siden det tillater fil-lesing av systemet
Gjenbruk av passord	Det blir brukt samme passord mot andre tjenester som øker risikoen for full kontroll av systemet
Open port	Det er porter som er unødvendig åpent som øker angrepsflaten til systemet, det er derfor anbefalt at man lukker disse portene.
Oppdatering av systemer	Det er flere utdaterte versjoner av pakker som systemet kjører som har kritiske sårbarheter i seg som kan føre til komplett kontroll av maskinen. Dette bør fikses så fort så mulig
Rense inputfelt	Det er mulig å kjøre vilkårlig kode på webapplikasjonen derfor er det nødvendig å rense for input. Det er en funksjon i kildekoden som gjør dette men det blir ikke brukt effektivt på alle feltene men på bare få felter.

Copyright © NYX Offensive Security

Sårbarhets Oversikt

Bildet under viser en illustrasjon over sårbarhetene som er funnet i denne sikkerhetsrevisjonen.



Copyright © NYX Offensive Security



Verktøy brukt under revisjonen

Verktøy	Beskrivelse
NMAP	Utføre full portskanning av maskinen og tjenester som kjøres på denne.
Nikto	Automatisk sårbarhet skanner, skanner hele webapplikasjonen for feil konfigurasjoner og typiske sårbarheter som XSS osv. Falsk positiv kan oppstå og det ble derfor testet manuelt for å bekrefte for sårbarhetene.
ZAP	Skanning av webapplikasjon funn av skjulte filer.
SQLMap	SQLMap automatiserer det å finne en SQL-Injeksjon til å kunne ta ut databasen ved hjelp av enkle kommander på verktøyet.
Hashcat	Brukt til å knekke passord hashes offline.
Webverktøy	Hashes og Crackstation for å finne passord til hashen som er funnet. Nettsidene har større forhåndskalkulerte hasher som gjør arbeidet lettere med å finne passord uten hashcat.
Burp suite	Ble brukt for å gå gjennom forespørsler mot serveren og mulighet for å endre før det ble sendt.
VScode	Brukt for å gå gjennom kildekode og søke etter sårbare kodefunksjoner i php som «exec» eller «fopen»
sslyze	Verktøy for å analysere SSL/TLS konfigurasjonen til serveren.
Exploit funnet på github: PwnKit	Ferdig laget script laget for å utnytte en sårbarhet enkelt.

Copyright © NYX Offensive Security



Tabell over sårbarheter

Kategori	Sårbarhet	Risiko
Sårbarhet-1	*Åpen bakdør direkte til serveren. Bakdøren kjører på port 42422*	**Kritisk**
Sårbarhet-2	*SQL-injeksjon*	**Kritisk**
Sårbarhet-3	*Server viser kobling til Database passord i klar tekst. Kan oppdages via LFI*	**Kritisk**
Sårbarhet-4	*Gjenbruk av passord*	**Kritisk**
Sårbarhet-5	*Debian 10 eldre versjon sårbar*	**Kritisk**
Sårbarhet-6	*Sudo eldre versjon sårbar Version: 1.8.27-1*	**Kritisk**
Sårbarhet-7	*pkexec / CVE-2021-4034*	**Kritisk**
Sårbarhet-8	*Local File Inclusion på søkefeltet*	**Høy**
Sårbarhet-9	*versjon av Kernel version: 4.19.0*	**Høy**
Sårbarhet-10	*IDOR sårbarhet/SQL sårbarhet*	**Høy**
Sårbarhet-11	*MD5 lagring av passord*	**Høy**
Sårbarhet-12	*XSS på Admin endepunkt*	**Høy**
Sårbarhet-13	*Passord tilgang til Abyss er lagret i md5*	**Høy**
Sårbarhet-14	*Ingen rate-limiting sårbar for bruteforce angrep og dos*	**Høy**
Sårbarhet-15	*Åpen SSH Port*	**Høy**
Sårbarhet-16	*Åpen tilgang til Administrator siden*	**Medium**
Sårbarhet-17	*Åpen port til web serveren 9999*	**Medium**
Sårbarhet-18	*CSRF token ikke lagt til*	**Medium**
Sårbarhet-19	*httponly flag er ikke satt*	**Medium**
Sårbarhet-20	*Svak RSA nøkkel*	**Medium**
Sårbarhet-21	*Eldre TLS versjon*	**Medium**
Sårbarhet-22	*Eldre OpenSSH versjon*	**Medium**
Sårbarhet-23	*Reflektert Cross-Site-scripting på Registrerings skjema*	**Lav**
Sårbarhet-24	*Clickjacking*	**Lav**
Sårbarhet-25	*skjult fil phpinfo.php*	**Lav**
Sårbarhet-26	*Server viser versjon nummer den kjører*	**Informasjon**
Sårbarhet-27	*Command injection mulighet i koden*	**Informasjon**

Copyright © NYX Offensive Security





SÅRBARHETER SOM ER FUNNET

BORIS LOCKPICK
Copyright © NYX Offensive Security

Funn av sårbarheter

Sårbarhet-1
Kritisk: Open bakdør på port 42422

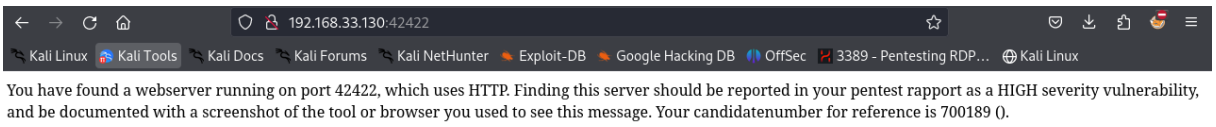
Beskrivelse

Under en full NMAP-skann så ble det avdekket at port 42422 var åpen, ved videre undersøkelse så ble det avdekket at denne porten kjøres på http. Ved å se i kildekode kan man også se at utvikleren har lagt inn bruker og passordet til bakdøren som kjøres. Her blir det brukt default credentials. Under videre undersøkelser av porten fant jeg en vei inn i serveren ved å logge inn med root:root som videre ga meg tilgang til filsystemer inne i serveren. Grunnen til at den får en kritisk og ikke en høy sårbarhet er fordi at det er en bakdør som gir tilgang til maskinen direkte fordi den har viktige filer som kan bli utnyttet til å få full tilgang til maskinen. Programmet som kjører på port 42422 ser ut til å være en egenutviklet http server bygget på C.

Det aktuelle området

Bakdøren kjøres på porten 42422 og kan kobles opp mot http, dette er en usikker tilkobling da dette kan avsløre klartekst datapakker gjennom nettverks verktøy som wireshark.

PoC /Bilde og beskrivelse



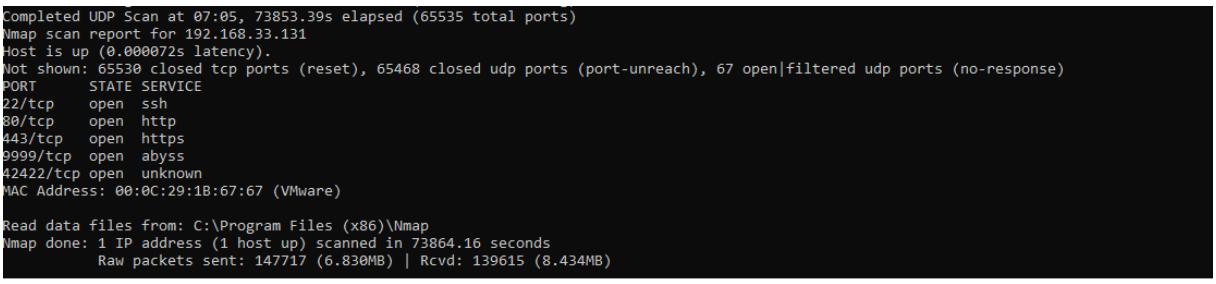
Ved å gå inn på nettleser og sjekke ut porten som kjøres så får jeg melding opp der må melde dette som en sårbarhet.

```
// TODO: What happens if the user connects to the port using telnet instead of http get? That could reveal
// that the user could send a LOGIN command using the credentials root:root opening the remote interface.
// This could be a security vulnerability and must be tested more before release...
```

Dette bildet viser kommentaren funnet på kildekoden som viser defualt credentials

Copyright © NYX Offensive Security

Det ble kjørt en full nmap skann som skanner alle portene fra 1 til 65535. Dette bildet viser selve Nmap-skanningen som viser til det åpne porten som kjøres. Det ble også kjørt full UDP scan noe som er treg og tidkrevende, men denne skanningen viste ikke noe relevant



Anbefalinger

- Det bør vurderes å ta ut porten og tjenesten som kjøres på denne siden dette da er en bakdør.

Copyright © NYX Offensive Security



Sårbarhet-2
Kritisk: SQL-injection

Beskrivelse

Registrerings skjema

På PHP koden **usrmgr_saveuser** så observeres det at «userID» har en funksjon som er ment for å sanitere bruker input, men videre så blir ikke dette gjennomført over til de andre input feltene. Det er også et annet problem med dette og det er at «userID» feltet saniterer ikke effektivt for SQL injeksjon selv om det fjerner de andre uttrykkene. Denne sårbarheten gjorde at jeg kunne dumpe databasen som var satt opp.

Login

På **login** endepunktet så er det en SQL error som kommer opp når man skriver feil passord for bruker. Her blir bruker input direkte satt inn til SQL uten validering eller parameterisering av bruker input til login feltet. Manglende sjekk gjør at en trusselaktør kan manipulere SQL spørring og dermed få kontroll på innholdet til databasen.

Cookie basket id

Når man skal prøve å kjøpe et produkt fra webapplikasjonen kan man endre på **cookie headeren** når du undersøker den på burp suite, ved å endre basket id og prøve og legge til en SQL-kommando så vil det komme opp en SQL error noe som tyder på en SQL-sårbarhet.

Addtobasket

Parameteren id som har som funksjon å legge inn varer i handlekurven blir ikke validert og blir direkte lagt inn i en SQL-spørring, ved å manipulere på verdien kan vi få opp en SQL-feil som viser til sårbarheten.

Det aktuelle området

Området for SQL injection

- Registrerings skjema
- Login
- Cookie basket id
- Addtobasket

Copyright © NYX Offensive Security

PoC /Bilde og beskrivelse

Registrerings skjema

```php
<?php

function _sanitizeinput($inputstring){

    $result = preg_replace('/[^A-Za-z0-9,.\-!]/', '', $inputstring);

    return $result;

}

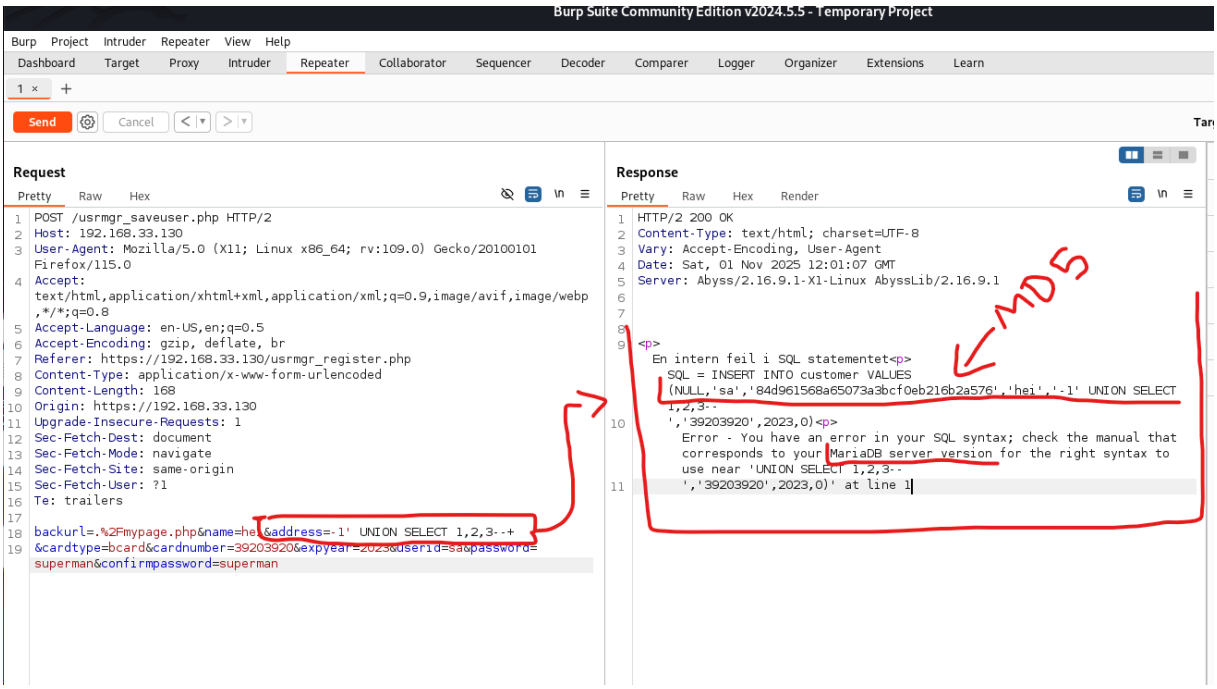
?>
```

Dette er selve funksjonen for å sanitere bruker input.



Copyright © NYX Offensive Security

PHP koden viser klart og tydelig at det prøves å sanitere input en bruker skriver som kan være skadelig. F.eks. på dette kan da være XSS men problemet er at det ikke vil effektiv sanitere for SQL kommandoer som UNIONSELECT og vil avsløre SQL databasen. Man kan se på koden at bruker input blir direkte matet inn på SQL spørringen.

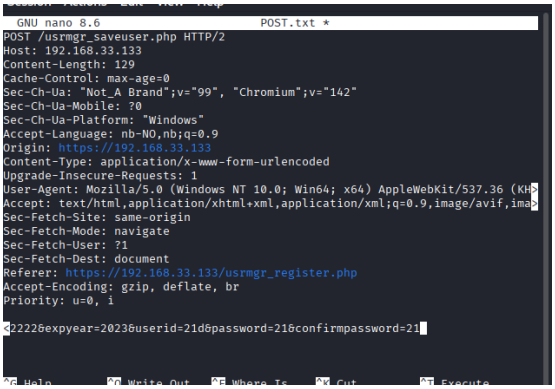


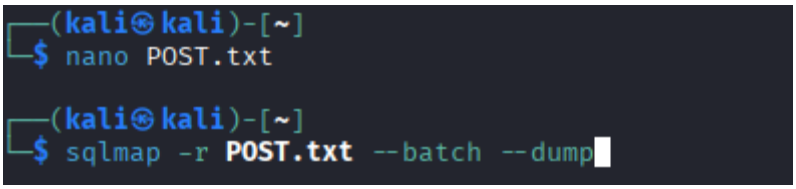
Eneste feltet som blir sanitert for Cross-Site Scripting (XSS) er userid feltet

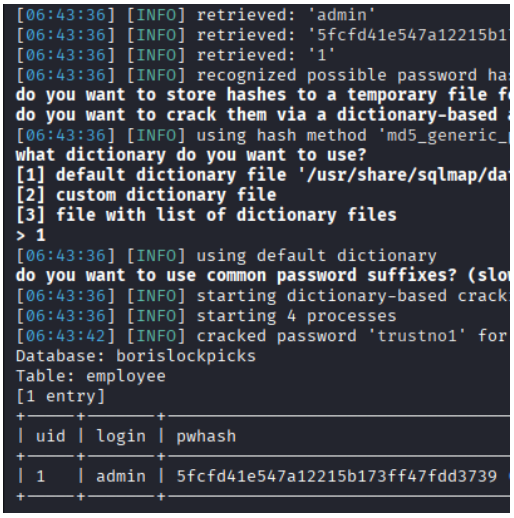


Copyright © NYX Offensive Security

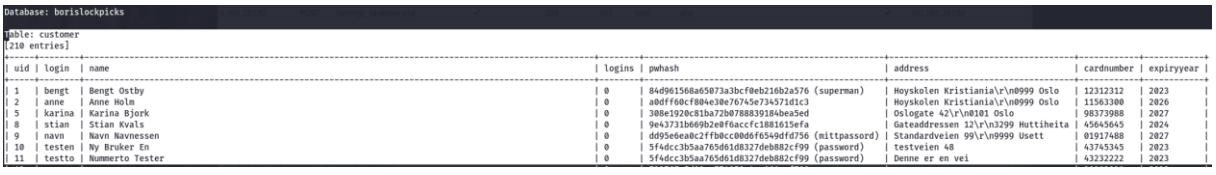
Ved å ta i bruk SQLmap fikk jeg muligheten til å ta ut innholdet til databasen, De fire bildene under viser måten dette er gjennomført på.







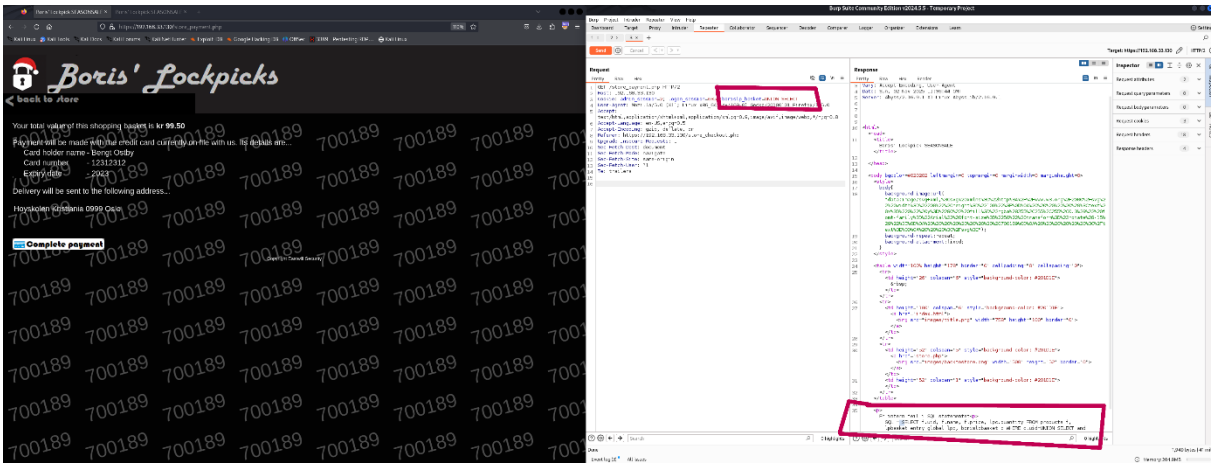
Bildet under viser brukere lagret på databasen i tillegg til hashene som SQLMap automatisk knakk.



Copyright © NYX Offensive Security

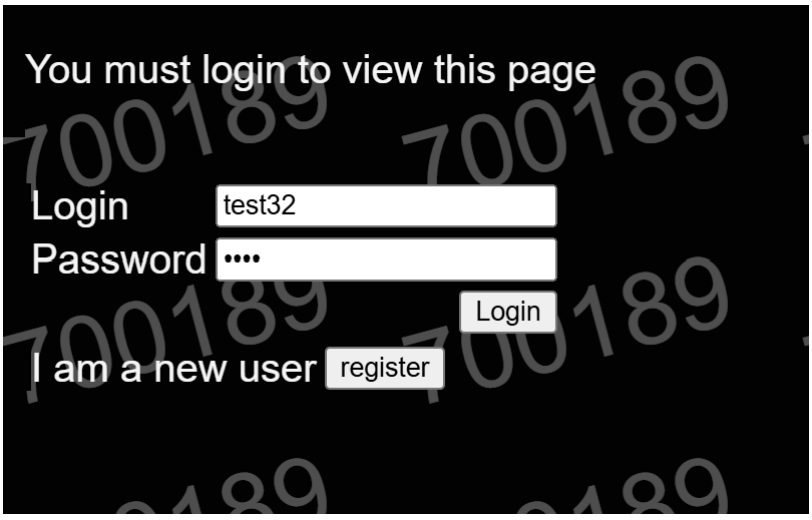
Cookie basket id

På bildet under ser man at man får en SQL error når man legger til en SQL-kommando på cookie headeren



Login endpunkt

Ved å skrive en tilfeldig bruker navn kommer man direkte til en SQL error noe som kan indikere for at man kan gjøre en SQL-injeksjon på login feltet.

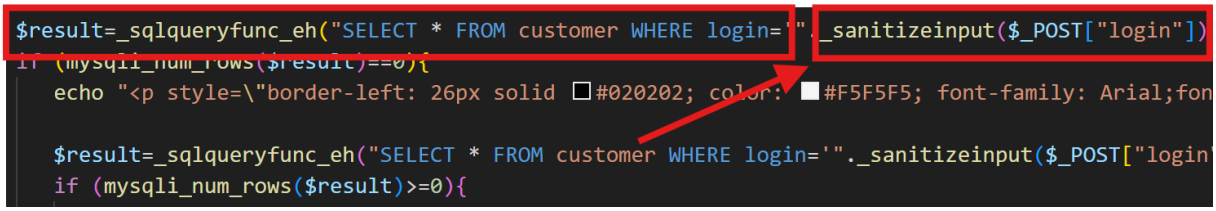


Copyright © NYX Offensive Security

Når man trykker login så kommer man til «invalid login» men hvis man ser nøye så kan du se svart tekst og ved å markere teksten kan vi se at det avslører en kritisk feil SQL error.

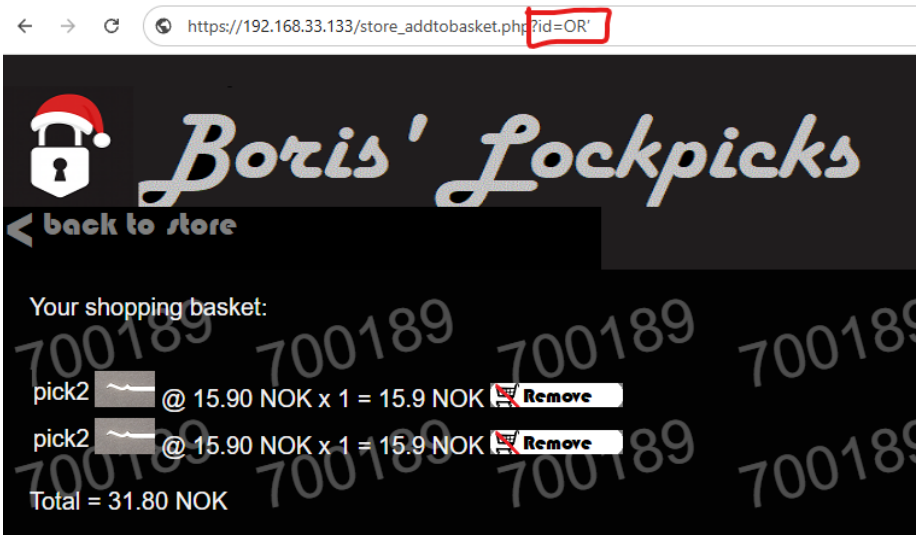


Ved å se på koden kan vi også se at login feltet blir renset før, men dette vil ikke hjelpe for SQL sårbarheten fordi det ikke blir brukt prepared statement



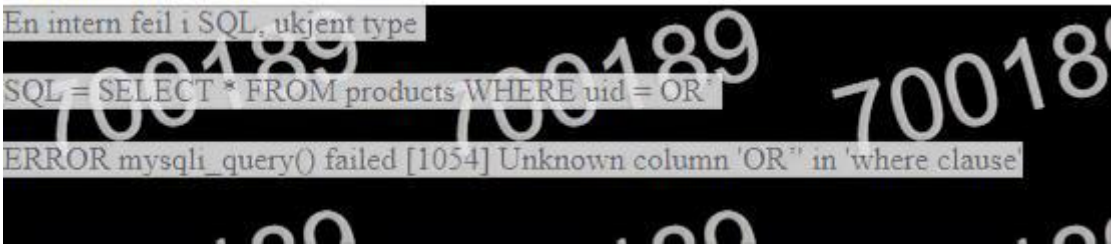
AddToBasket endpunkt

Bildet under viser ved å erstatte id=2 til id=OR` kan man utløse en SQL error



Bildet under viser SQL error som bekrefter en annen vei for SQL injeksjon.

Copyright © NYX Offensive Security



Anbefalinger

- Det vil anbefales for at det blir brukt «**prepared statement**» for SQL spørringene. Dette betyr at spørringene er fra før kompilert og input verdiene blir plassert i (?). Bildet under er eksempel på hvordan dette ser ut.
- Valider alle URL-parametere
- Sørge for at Id kan kun forvente heltall



(Bilde: https://tiloid.com/p/preventing-sql-injection-in-php)

Copyright © NYX Offensive Security

Sårbarhet-3
Høy: Local File inclusion på søkefeltet

Beskrivelse

På webapplikasjonen så er sårbarheten Local File Inclusion en av de største sårbarhetene fremtreden på webapplikasjonen. Dette er en av de mest alvorlige sårbarhetene som finnes på nettsiden fordi det gir tilgang til å lese på filene som er på serveren. Grunnen til at denne sårbarheten får høy sårbarhet er fordi den gir deg bare tilgang til å lese filene inne i systemet. Her må angriper kombinere andre sårbarheter i systemet for å kunne komme seg fullt inn i systemet.

Det aktuelle området

Søkefeltet

PoC /Bilde og beskrivelse

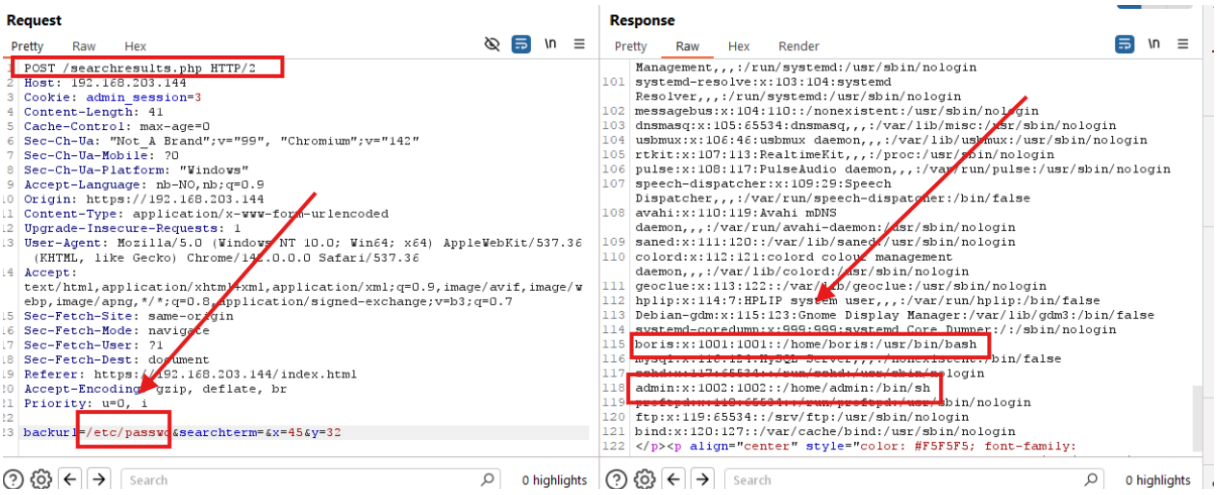
Ved å gå gjennom koden så oppdaget jeg å kode funksjonen «fopen» i en input som ikke er sanitert gjør det mulig for en angriper å endre filstien til /etc/passwd

```
$handle = fopen ($_POST["backurl"], "r");
if ($handle != FALSE){
    while (!feof ($handle)) {
        $buffer = fgets($handle, 4096);
        echo $buffer;
    }
```

Dette er det jeg får opp ved å undersøke POST requesten på burp suite ved å endre til linux filsti så ser vi på det tredje bildet at jeg får opp liste over brukerkontoer på systemet som kjører webserveren.

Copyright © NYX Offensive Security





Anbefalinger

- Det anbefales at man kontrollerer input feltet sånn at en bruker ikke kan få tilgang til eksterne filer til systemet

Copyright © NYX Offensive Security

Sårbarhet-4
Kritisk: Server viser kobling til MYSQL passord i klar tekst. Kan oppdages via LFI

Beskrivelse

Filstien i kildekoden viser til en konfigurasjonsfil der databasen sin brukernavn og passord er i klar tekst noe som gjør at man får tilgang til databasen viss denne hadde en åpen port tilgjengelig. Hovedproblemet ligger i at man lagrer en konfigurasjonsfil som er sensitive i klartekst noe som gjør sårbarheten høy i seg selv, men grunnen til at denne sårbarheten er klassifisert som kritisk sårbarhet ligger i at passordet har blitt brukt til å komme seg helt inn i maskinen og fått full kontroll av hele systemet bare ved å ha passordet i klartekst.

Det aktuelle området

Ved å gå inn på kildekoden så ser man hvor konfigurasjonsfilen er.

"../boris_config/settings.conf";

PoC /Bilde og beskrivelse

Ved å ta i bruk en annen sårbarhet som Local file inclusion kan en angriper sjekke ut alle passord og brukernavn som er lagret på systemet. På bilde under ser vi at passord er i klar tekst noe som kan gi angriper flere veier å komme seg videre inn på systemet. Selv om databasen ikke har porten åpen er bare det å få passord og brukernavn nok til å skaffe seg tilgang til maskinen viss disse blir brukt i andre tjenester i systemet.



Copyright © NYX Offensive Security



Anbefalinger

- Sensitive Konfigurasjons filer må flyttes inn i egne sikre miljøvariabler med begrensede rettigheter
- Loggfør hvem som har sett på filene
- Mest mulig å unngå klartekst på sensitive filer

Copyright © NYX Offensive Security



Sårbarhet-5
Kritisk: gjenbruk av passord

Beskrivelse

Alle bruker navn og passord som ble funnet gjennom sårbarhetene, som stammer fra databasen og konfigurasjon filen til databasen så ble disse prøvd opp mot SSH tilkobling noe som ga meg tilgang til maskinen. Gjenbruk av passord på andre tjenester utgjør en kritisk sårbarhet fordi ved å sikre systemer lagvis så kan vi unngå at en angriper får tilgang til en annen tjeneste når først et passord er funnet.

Når jeg fikk tilgang maskinen var neste steget å få økt mine priviliger og siden maskinen kjører eldre versjoner finnes det flere veiere for å oppnå dette. En av de enkleste måtene for å oppnå dette er bruk av kommandoen «su root» og bruke det samme passordet som jeg fant ved database konfigurasjons filen. «correcthorse»

Det aktuelle området

- Lokalt i maskinen
- Database tilkobling
- SSH

PoC /Bilde og beskrivelse

Ved å bruke det samme passord som jeg fant på en tidligere sårbarhet kunne jeg logge inn på maskinen gjennom SSH.

Copyright © NYX Offensive Security



```
┌──(kali㉿kali)-[~]
└─$ ssh admin@192.168.33.133
The authenticity of host '192.168.33.133 (192.168.33.133)' can't be establish
ed.
ED25519 key fingerprint is SHA256:Vki2S1UwdmK4bfwG/t9cDu7yyrldROxejNzPlU+b3w4
.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.33.133' (ED25519) to the list of known ho
sts.
admin@192.168.33.133's password:
Linux osboxes 4.19.0-5-amd64 #1 SMP Debian 4.19.37-5 (2019-06-19) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Nov 15 16:20:28 2025 from 192.168.33.1
$ whoami
admin
$
```

Ved å logge seg inn lokalt i maskinen kan vi også bruke samme passord både lokalt og for å øke privliger

```
root@osboxes:/home/boris/apps/abysssws# su admin
$ su root
Password:
root@osboxes:/home/boris/apps/abysssws#
```

Anbefalinger

- Bruk av unike passord for hver tjeneste som blir brukt. Eks: Database tilkobling eller SSH

Copyright © NYX Offensive Security

Sårbarhet-6
Kritisk: Debian 10 eldre versjon sårbar

Beskrivelse

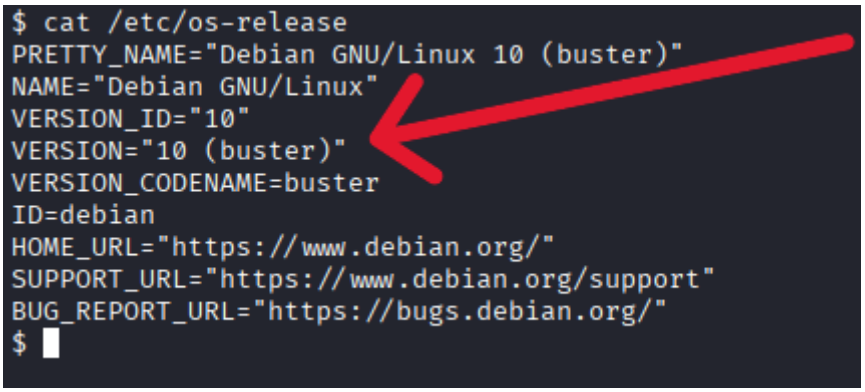
Debian 10 er et eldre Linux distribusjon som har flere pakker med kritiske sårbarheter i seg. Disse sårbarhetene utgjør en kritisk risiko og grunnen til dette er fordi en angriper kan bruke disse sårbarhetene til å forhøye sine priviliger på systemet noe som betyr totalt tap av data.

Det aktuelle området

Lokalt i maskinen

PoC /Bilde og beskrivelse

Ved å sjekke for versjon nummer av distribusjonen så kan vi se at dette er en eldre versjon av som finnes per dags dato



Anbefalinger

- Full Oppgradering av Debian systemet

Copyright © NYX Offensive Security

Sårbarhet-7
Kritisk: Sudo eldre versjon sårbar Version: 1.8.27-1

Beskrivelse

Under full undersøkelse av systemet, så oppdaget jeg at systemet kjører Sudo versjon 1.8.27 som er kjent for en rekke kjente sårbarheter. CVE-2021-3156 er en av de mest kritiske sårbarhetene som finnes i denne sudo versjonen. Denne sårbarheten sørger for at man får full root tilgang til systemet uten passord. Grunnen til at denne får kritisk er fordi ved å få root tilgang har man i praktisk full tilgang til maskinen og kan gjøre stor skade på systemene til webapplikasjonen.

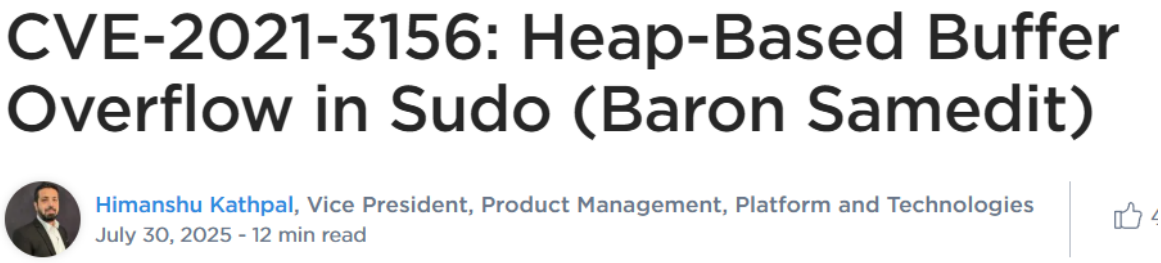
Det aktuelle området

Lokalt i maskinen.

PoC /Bilde og beskrivelse

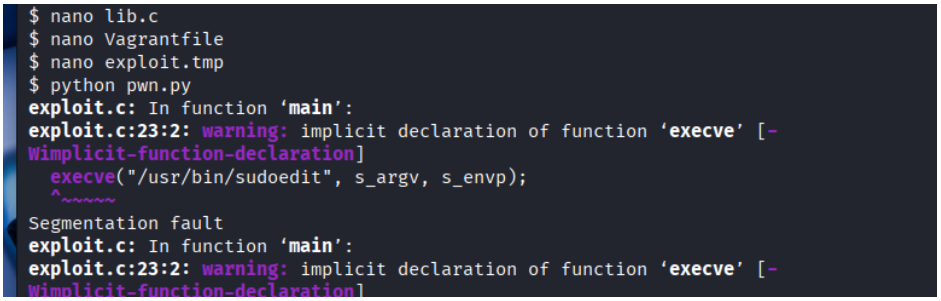
Ved å se hvilken versjon som kjører kan jeg bruke denne informasjonen til å søke etter sårbarheter som finnes i denne versjonen.

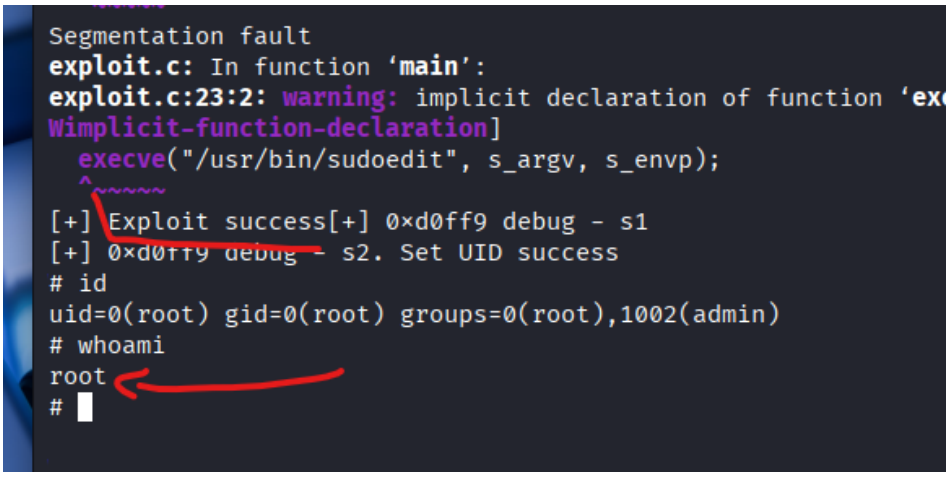
```
$ sudo -V
Sudo version 1.8.27
Sudoers policy plugin version 1.8.27
Sudoers file grammar version 46
Sudoers I/O plugin version 1.8.27
```



Copyright © NYX Offensive Security

Bildene under viser en utnyttelse/exploit som er funnet på github og demonstrer hvordan en angriper lett kan få **Root** tilgang med denne exploiten. Denne exploiten ble kjørt gjennom SSH for å demonstrere at man ikke trenger tilgang til maskinen som kjører webapplikasjonen fysisk.





Anbefalinger

- Det anbefales for å oppdatere til nyere sudo versjon

Referanser

For mer detaljer se her

https://blog.qualys.com/vulnerabilities-threat-research/2021/01/26/cve-2021-3156-heap-based-buffer-overflow-in-sudo-baron-samedit

Exploit koden: https://github.com/dinhbaouit/CVE-2021-3156?tab=readme-ov-file

Copyright © NYX Offensive Security

Sårbarhet-8
Kritisk: pkexec / CVE-2021-4034

Beskrivelse

Polkit pakken til Linux har versjon nummer 0.105 som har en kjent kritisk sårbarhet CVE-2021-4034 som kan gi en angriper forhøyede priviliger til maskinen lokalt. Dette er klassifisert kritisk sårbarhet fordi denne sårbarheten gir full kontroll over maskinen.

Det aktuelle området

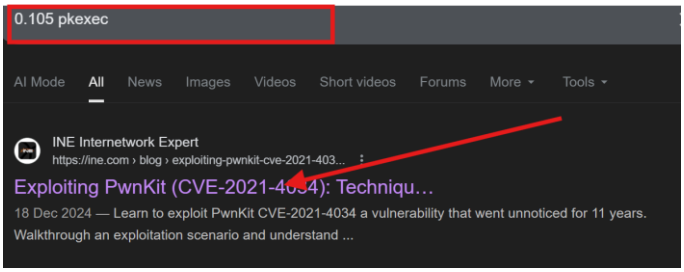
Maskinen lokalt

PoC /Bilde og beskrivelse

Ved å se på hvilken version pekexec kjører kan vi søke dette opp mot sårbarheter som finnes

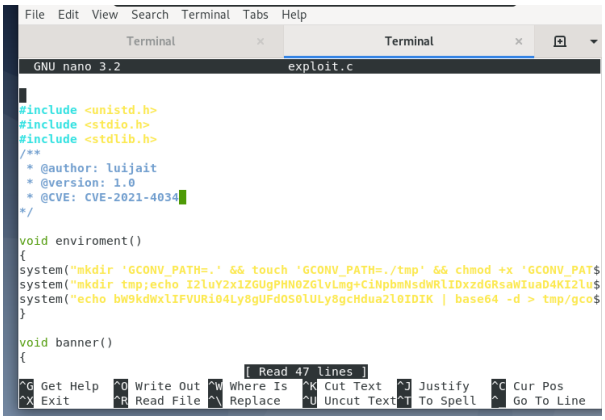
```
$ pkexec
pkexec --version |
       --help |
       --disable-internal-agent |
       [--user username] PROGRAM [ARGUMENTS...]

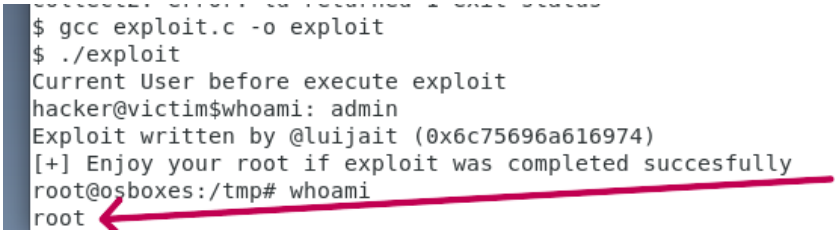
See the pkexec manual page for more details.
pkexec version 0.105
```



Copyright © NYX Offensive Security

Bildet under viser bruk av PwnKit exploiten, ved å kjøre denne fikk jeg tilgang til hele systemet.





Anbefalinger

- Oppdatering av Polkit pakken til Linux

Copyright © NYX Offensive Security

Sårbarhet-9
Kritisk: Versjon av Kernel version: 4.19.0

Beskrivelse

Maskinen kjører kernel versjon 4.19.0 som er en eldre kernel med flere kjente sårbarheter. Det er kjernen som er det kritiske komponenten i et operativsystem, Ved å benytte seg å disse sårbarhetene kan en angriper eskalere sine privilegier siden kernel ikke er oppdatert.

Det aktuelle området

lokalt på maskinen

PoC /Bilde og beskrivelse

Bildet under viser versjon nummer for kernel

```
root@osboxes:/home/admin# uname -a
Linux osboxes 4.19.0-5-amd64 #1 SMP Debian 4.19.37-5 (2019-06-19) x86_64 GNU/Linux
```

Anbefalinger

- Fullstendig oppgradering: systemet må oppgraderes til et nyere kjerneversjon.
- Rutine: Regelmessige rutiner for å sjekke kjernen og oppdatere systemene.

Referanser:

For mer detaljer se her: Hvordan sjekke for kernel versjon på linux

https://askubuntu.com/questions/359574/how-do-i-find-out-the-kernel-version-i-am-running

Copyright © NYX Offensive Security

Sårbarhet-10
Kritisk: IDOR/SQL injeksjon

Beskrivelse

Denne sårbarheten ble først oppdaget som en SQL-injeksjon men jeg vil også klassifisere denne som en IDOR sårbarhet. Grunnen til dette er at man kan bare endre nummer i «USERID» feltet eller sånn det står på burp suite logon_session. Ved å endre fra 632 til 635 fikk jeg opp andre opplysninger fra en annen bruker som bekrefter problemet i koden. Hovedproblemet i IDOR er har med SQL sårbarheten og gjør fordi USERID blir direkte brukt i SQL spørringen.

Det aktuelle området

Ved å endre på forespørsler ved cookie headeren på end punktet /store_payment.php og endring av «USERID» på URL vil også kunne trigge sårbarheten

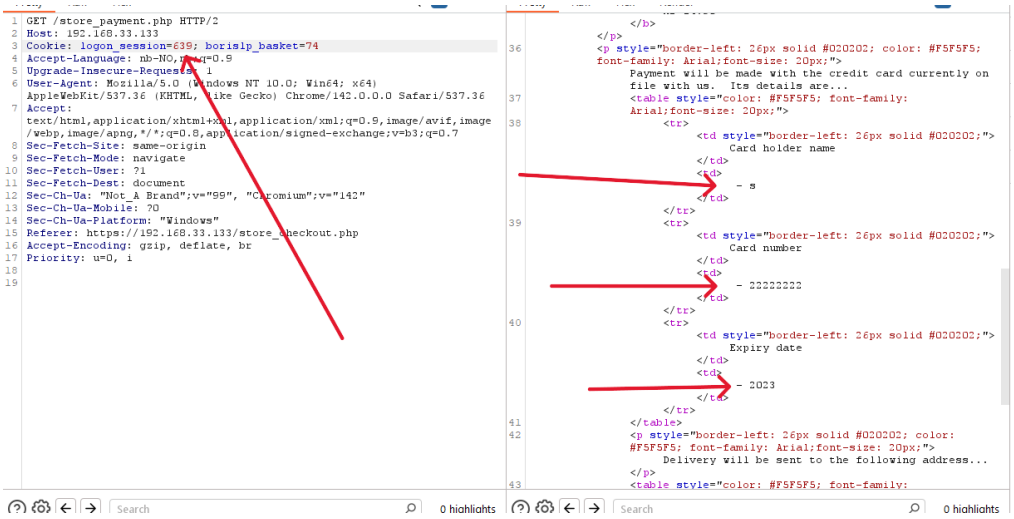
PoC /Bilde og beskrivelse

Bildet under viser først det oppdagede feltet som viser sårbarheten, her kan man se «USERID» variabelen bli brukt direkte i en spørring. Selv om dette ikke er bruker input kan en trussel aktør benytte seg av denne type sårbarhet ved å inspisere forespørselen som går til serveren.

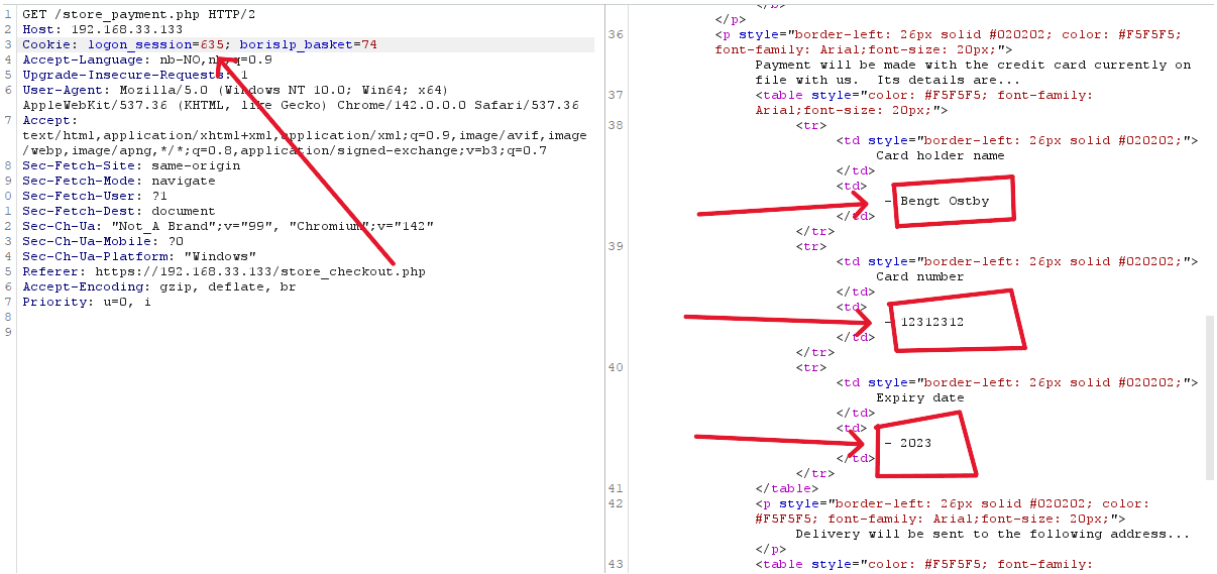
```
$quser=_sqlqueryfunc_eh("SELECT * FROM customer WHERE uid=$userid");
```


Copyright © NYX Offensive Security

Ved å endre ID så ser vi at applikasjonen viser en annen profil som er fra databasen.

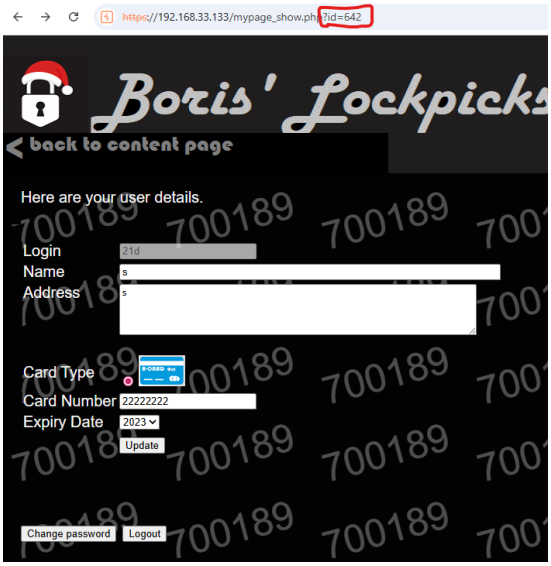


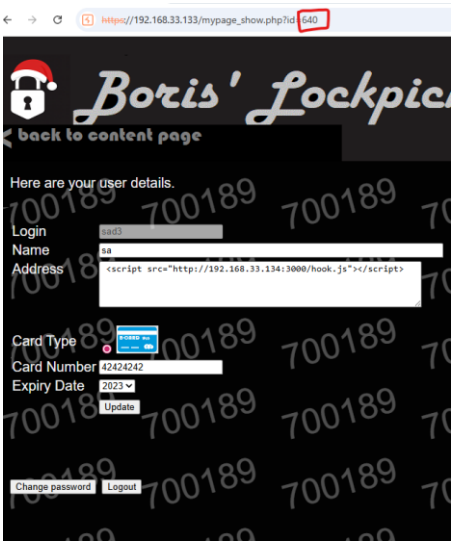
Bildet under viser hva vi får opp ved å endre til verdi 635



Copyright © NYX Offensive Security

Vi får også samme får samme sårbarhet ved også gå inn på endepunkt til mypage som viser at samme sårbarhet og metode er implementert på dette endepunkt. /mypage_show.php?id=642 bare at denne gangen kan man også endre via URL parameteren.





Anbefalinger

- Sørge for autorisering på server slike at bare brukere skal kunne få tilgang til egn profil
- Bruk av prepared statement og ikke bruk direkte «userId» på SQL-spørringen

Copyright © NYX Offensive Security

Sårbarhet-11
Høy: Passord lagret i MD5

Beskrivelse

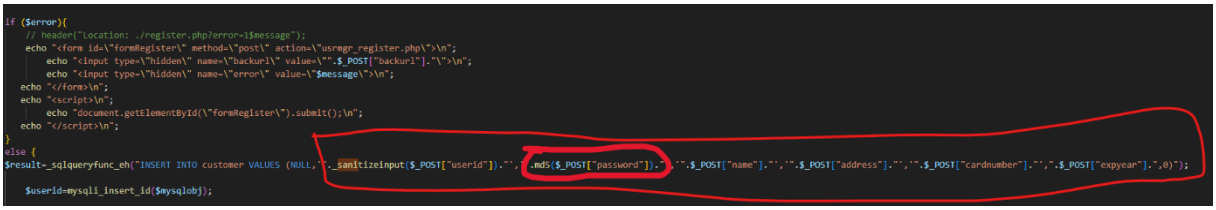
Passord fra brukere blir lagret i form av MD5, å lagre passord i form av MD5 utgjør en større risiko fordi det vil tillate for knekking av passord på en enkelt og kjapp måte. En angriper trenger ikke som oftest å knekke disse, men kan heller bruke en nettbasert tjeneste som kan sjekke hash opp mot sin database. MD5 blir ikke og bør ikke bli brukt som måte å lagre passord på. MD5 er kjent for å være rask og blir brukt for checksum av filer for eksempel.

Det aktuelle området

Dette funnet gjelder måten passord blir lagret på så dette gjelder systemets database.

PoC /Bilde og beskrivelse

Sårbarheten ble oppdaget på ved å se på registrerings skjemaet i php koden, der ser man at det blir benyttet hashing av passord, men dette blir gjennomført på en svak måte ved å bruke en sårbar hashing algoritme.



```
if ($error){
    // header("Location: ../register.php?error=1$message");
    echo "<form id=\"formRegister\" method=\"post\" action=\"usrmgr_register.php\">\n";
        echo "<input type=\"hidden\" name=\"backurl\" value=\"".$_POST["backurl"]."\">\n";
        echo "<input type=\"hidden\" name=\"error\" value=\"$message\">\n";
    echo "</form>\n";
    echo "<script>\n";
        echo "document.getElementById(\"formRegister\").submit();\n";
    echo "</script>\n";
}
else {
$result=_sqlqueryfunc_eh("INSERT INTO customer VALUES (NULL,'".._sanitizeinput($_POST["userid"])."','".md5($_POST["password"])."','".$_POST["name"]."','".$_POST["address"]."','".$_POST["cardnumber"]."','".$_POST["expyear"].",0)");

    $userid=mysqli_insert_id($mysqlobj);
```

På bildet under kan du se passord lagret i hash



Database: borislockpicks

Table: customer
[210 entries]

uid	login	name	logins	pwhash	address	cardnumber	expiryyear
1	bengt	Bengt Ostby	0	84d961568a65073a3bcf0eb216b2a576 (superman)	Hoyskolen Kristiania\r\n0999 Oslo	12312312	2023
2	anne	Anne Holm	0	a0dff60cf804e30e76745e734571d1c3	Hoyskolen Kristiania\r\n0999 Oslo	11563300	2026
5	karina	Karina Bjork	0	308e1920c81ba72b0788839184bea5ed	Oslogate 42\r\n0101 Oslo	98373988	2027
8	stian	Stian Kvals	0	9e43731b689b2e0f6accfc1881615efa	Gateaddressen 12\r\n3299 Huttiheita	45645645	2024
9	navn	Navn Navnessen	0	dd95e6ea0c2ffb0cc00d6f0549dfd756 (mittpassord)	Standardveien 99\r\n9999 Usett	01917488	2027
10	testen	Ny Bruker En	0	5f4dcc3b5aa765d61d8327deb882cf99 (password)	testveien 48	43745345	2023
11	testto	Nummerto Tester	0	[illegible] (password)	Denne er en vei	43232222	2023

Copyright © NYX Offensive Security



Fra en tidligere sårbarhet har jeg hash-verdien til admin og bruke dette opp mot hashcat verktøyet som kan dekryptere dette opp mot en stor ordliste.

```
[06:43:36] [INFO] retrieved: 'admin'
[06:43:36] [INFO] retrieved: '5fcfd41e547a12215b1
[06:43:36] [INFO] retrieved: '1'
[06:43:36] [INFO] recognized possible password ha
do you want to store hashes to a temporary file f
do you want to crack them via a dictionary-based
[06:43:36] [INFO] using hash method 'md5_generic_
what dictionary do you want to use?
[1] default dictionary file '/usr/share/sqlmap/da
[2] custom dictionary file
[3] file with list of dictionary files
> 1
[06:43:36] [INFO] using default dictionary
do you want to use common password suffixes? (slo
[06:43:36] [INFO] starting dictionary-based crack
[06:43:36] [INFO] starting 4 processes
[06:43:42] [INFO] cracked password 'trustno1' for
Database: borislockpicks
Table: employee
[1 entry]
+-----+-------+----------------------------------
| uid | login | pwhash
+-----+-------+----------------------------------
| 1   | admin | 5fcfd41e547a12215b173ff47fdd3739
+-----+-------+----------------------------------
```

Ved å ta hash verdien og lagre det i en text så kan man bruke hashcat til å dekryptere hashverdien offline.

```
┌──(kali㉿kali)-[~]
└─$ hashcat -m 0 -a 0 brute.txt /usr/share/wordlists/rockyou.txt
```

Bildet under viser resultatet fra hashcat som viser hvor enkelt det tok meg å knekke denne MD5 verdien.

```
* Bytes.....: 139921507
* Keyspace..: 14344385
* Runtime...: 1 sec

5fcfd41e547a12215b173ff47fdd3739:trustno1

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 0 (MD5)
```


Copyright © NYX Offensive Security



Anbefalinger

Det anbefales at blir brukt en sikrere algoritme for lagring av passord, det finnes flere som fungerer bra og er tid krevende og resurskrevende for å knekke disse. Argon2 er et eksempel på en vel fungerende algoritme som også vant hashing konkurransen i 2015.

- Argon2
- PBKDS2
- bcrypt

Referanser

For mer detaljer se her:

https://medium.com/@smujtabaja/some-hashing-algorithms-their-strength-ratings-426e35c8ef18

Copyright © NYX Offensive Security

Sårbarhet-12
Høy: XSS på Admin endpunkt

Beskrivelse

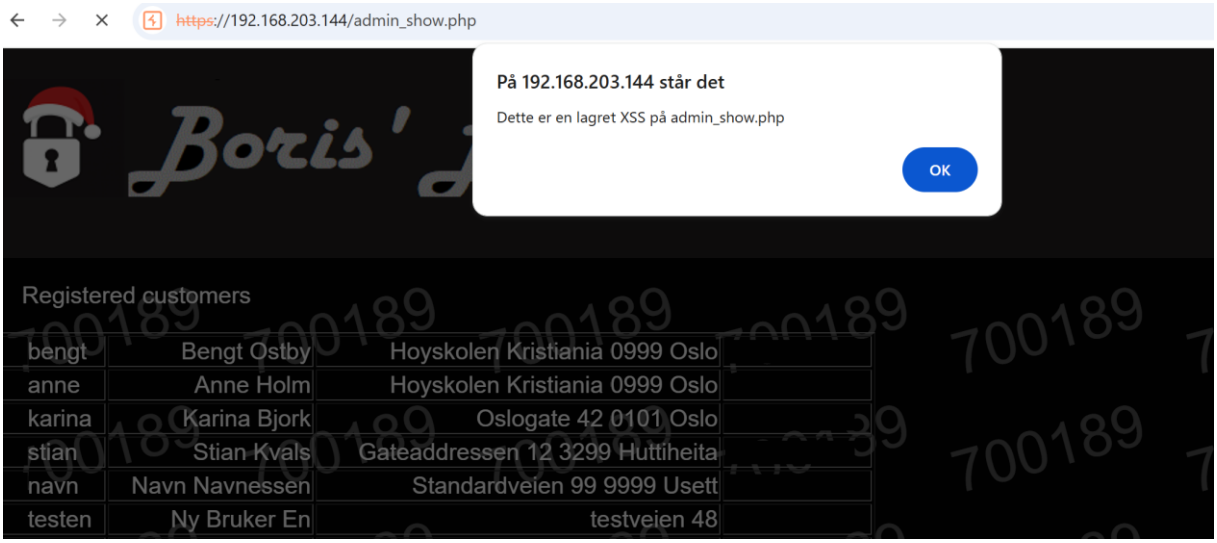
På endepunktet Admin så er det et inputfelt der en admin/bruker kan skrive på loggen, ved å legge inn en script som javascript kunne jeg kjøre kode som ikke bare blir lagret på min nettleser, men på selve serveren som kjører webapplikasjonen. Dette kalles for en Persistent XSS og gjør at sårbarheten går fra å være et medium sårbarhet til en høy sårbarhet.

Det aktuelle området

/admin_show.php på input feltet til Work log

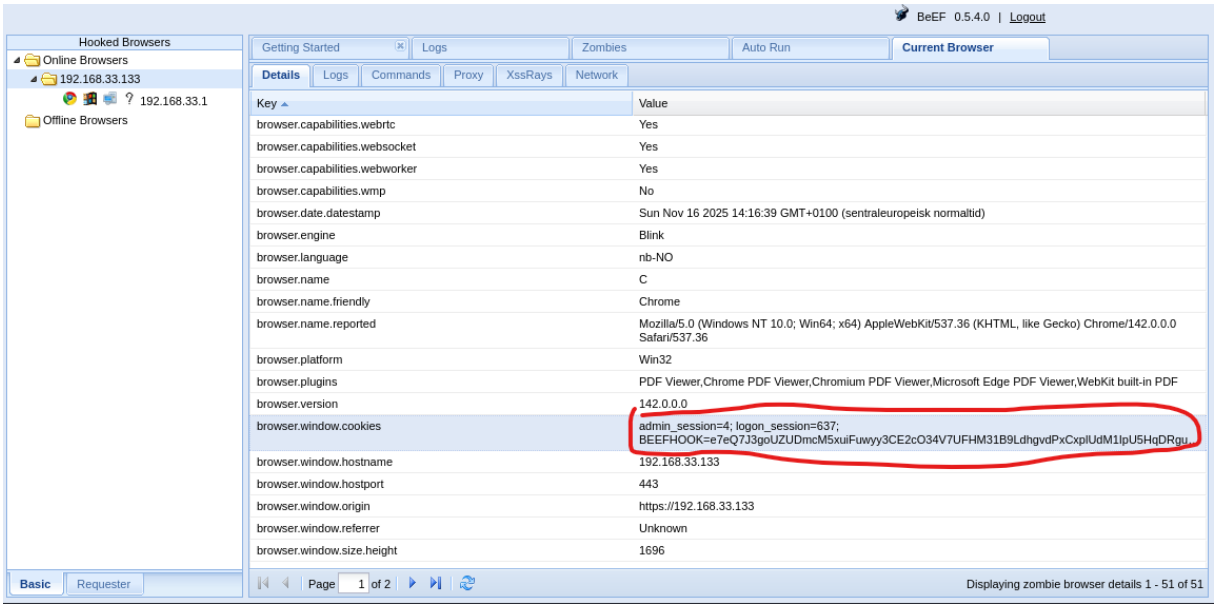
PoC /Bilde og beskrivelse

Denne testen beviser at den tar imot koden og kjører denne koden.



Dette eksemplet viser hvordan en typisk trussel aktør kan ta i bruk verktøy som BeeF og bruke dette til å utnytte nettleseren til andre brukere i webapplikasjonen. Det BeeF gjør er å legge inn en javascript kode inn i webapplikasjonen og siden denne blir lagret i serveren kan angriperen da få full kontroll over nettleserne til alle som besøker siden. Under bildet kan du se at jeg har fått taket i coockie session fra brukeren.

Copyright © NYX Offensive Security



Anbefalinger

- Det bør bli brukt streng kontroll av brukerinput som å iverksette santerning av input.

Copyright © NYX Offensive Security

Sårbarhet-13
Høy: Passord tilgang til Abyss er lagret i md5

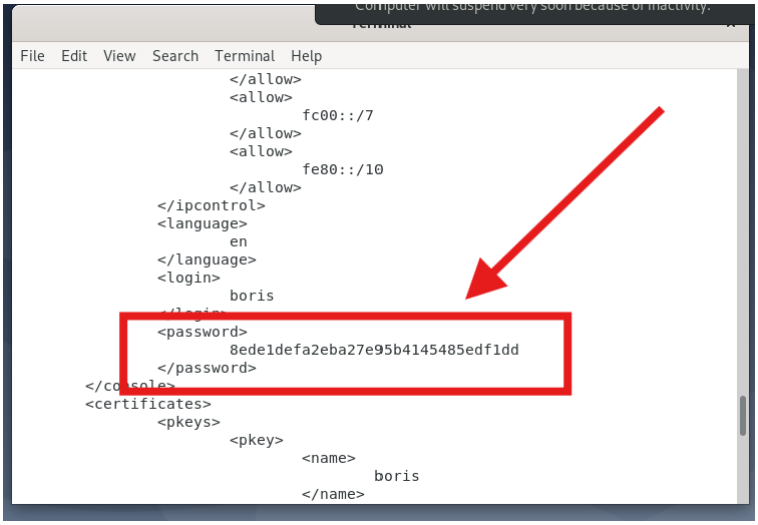
Beskrivelse

Ved å gå inn på konfigurasjons filen til Abyss serveren så kan vi se at passordet er lagret i MD5 som gjør passord lett å knekke. Det ble prøvd å knekke dette passordet med hashcat og hashes.com men fant ikke noe passord fra disse. Selv om passord er unik så anbefales det fortsatt å bruke sterkere algoritme.

Det aktuelle området

Lokalt i maskinen Abyss konfigurasjonsfil.

PoC /Bilde og beskrivelse



Anbefalinger

- Bruk av sterkere algoritme tidligere anbefalt er bcrypt

Copyright © NYX Offensive Security

Sårbarhet-14
Høy: Ingen rate-limiting sårbar for Brute force angrep og dos

Beskrivelse

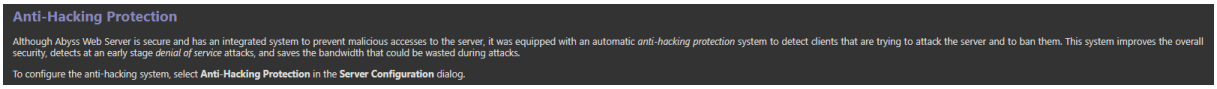
Webapplikasjonen har ingen Rate-Limiting som gjør den sårbar for «Dos» angrep. Dette er et problem fordi webserveren ikke har en funksjon for å hindre forespørsler mot Webapplikasjonen. Funksjonen aktivert vil kunne blokkere IP-adresser som har mange forespørsler i sekundet og blokkere disse ip adressene mot å komme seg inn i webapplikasjonen.

Det aktuelle området

Port: 80

PoC /Bilde og beskrivelse

Bildet under viser dokumentasjon som viser hvordan Anti-hacking funksjon skal fungere og hva dette er.



Bildet viser konfigurasjon som er satt for webserveren og viser at Anti hack funksjonen ikke er aktivert

Copyright © NYX Offensive Security



Anbefalinger

```
<antihack>
        <enabled>
                no
        </enabled>
        <threshold>
                20
        </threshold>
        <monitorperiod>
                20
        </monitorperiod>
        <banperiod>
                60
        </banperiod>
        <logfile/>
        <denied>
                <ip>
                        127.0.0.1
                </ip>
                <ip>
                        ::1
                </ip>
        </denied>
</antihack>
```

Referanser

For mer detaljer se her: Abyss dokumentasjon

https://aprelium.com/abyssws/features.html

Copyright © NYX Offensive Security

Sårbarhet-15
Høy: Åpen SSH port

Beskrivelse

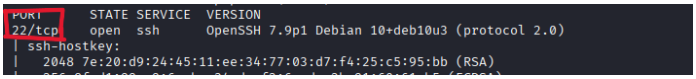
Utifra Nmap skanningen kunne jeg avdekke at Port 22 kjører som ikke er anbefalt praksis, det å ha en kjørende port som 22 gir en ekstra angrepsflate til en trusselaktør. SSH protokollen er sikker og krypterer kommunikasjonen. Selv om den er trygg å bruke så kan en angriper kunne bruteforce altså knekke denne autentiseringen og som vi vet er passord i seg selv lett å knekke. Grunnen til at den blir klassifisert som Høy risiko er fordi at passordet kan bli hentet fra andre metoder som gjør at tilgang til maskinen blir enkelt.

Det aktuelle området

Port: 22

PoC /Bilde og beskrivelse

Bildet under viser Nmap scann der man kan observere at SSH porten kjører



Anbefalinger

- Bør lukkes om den ikke er nødvendig å ha kjørende
- Det anbefales å legge til brannmur regler for ip adresser som vil koble til

Copyright © NYX Offensive Security

Sårbarhet-16
Medium: Åpen tilgang til Administrator siden

Beskrivelse

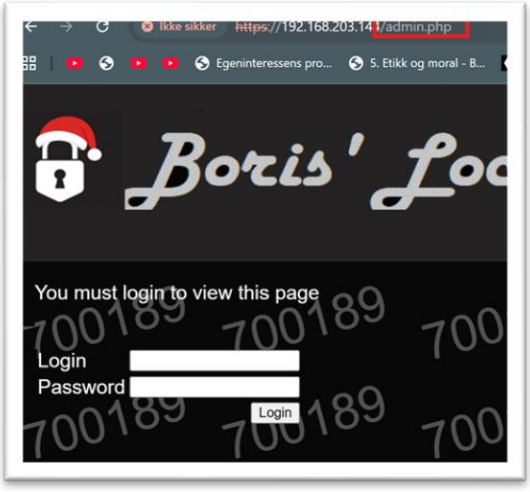
Fra kilde koden kan man se at det er et endepunkt for å håndtere det administrative oppgavene som å få opp alle som er registrert på webapplikasjonen. Eneste som beskytter denne endepunktet er enkel login som kan bli knekket med bruteforcing eller gjennom andre sårbarheter kommet seg gjennom autoriseringen.

Det aktuelle området

/Admin.php

PoC /Bilde og beskrivelse

Ved å skrive Admin.php på siden kan man få tilgang til admin siden til webapplikasjonen, eneste som hindrer dette er en enkel login side som kan bli brutt inn med lite ressurser fra en angripers perspektiv.



Copyright © NYX Offensive Security



Anbefalinger

- bruk av streng multi-faktor autentisering kan hindre uvedkommende å få tilgang til admin siden viss det er nødvendig å ha dette endepunktet åpent.
- Det anbefales på det sterkeste at denne admin siden ikke er åpen og kan nås fra vpn eller bruk av brannmur.

Copyright © NYX Offensive Security

Sårbarhet-17
Medium: Open port til web serveren 9999

Beskrivelse

Under en Nmap-skanning ble port 9999 fanget opp som tilfører Abyss-webserveren. Selv om dette er bak en autentisering, er selve tjenesten fortsatt der ute og er eksponert. Dette kan bety at en trussel aktør kan fange opp hva som kjøres bak port 9999 og øke angrep flaten ved å få opp mer informasjon fra webserveren. Her kan også en angriper Brute force seg inn på porten noe som igjen øker sjansen for å gi angriper kontroll over serveren. Den får en Medium risiko fordi tjenesten ikke er åpent og er lukket bak autentisering, men gir likevel angriper en ekstra angrepsflate.

Det aktuelle området

Port: 9999

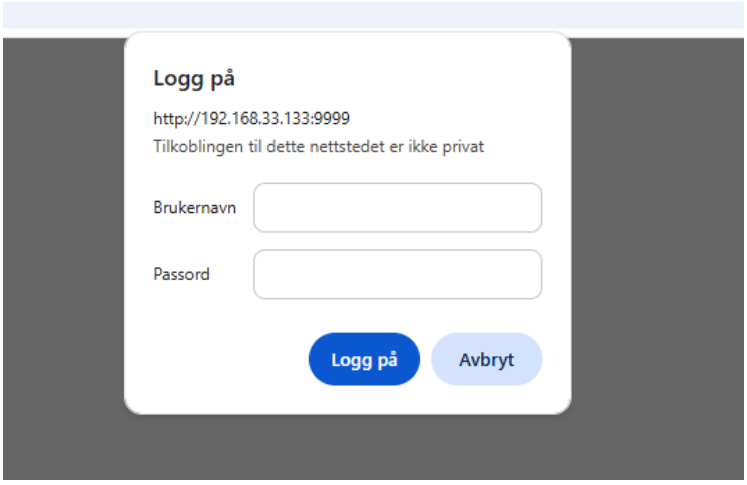
PoC /Bilde og beskrivelse

Nmap skanning som viser sårbarheten

```
Completed UDP Scan at 07:05, 73853.39s elapsed (
Nmap scan report for 192.168.33.131
Host is up (0.000072s latency).
Not shown: 65530 closed tcp ports (reset), 65468
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
443/tcp   open  https
9999/tcp  open  abyss
42422/tcp open  unknown
MAC Address: 00:0C:29:1B:67:67 (VMware)

Read data files from: C:\Program Files (x86)\Nmap
```

Bildet viser hva som dukker opp når man prøver å besøke 9999 porten



Copyright © NYX Offensive Security



Anbefalinger

- Denne porten bør bli lukket og kun være tilgjengelig gjennom maskinen som kjører webserveren
- Hvis det er nødvendig å ha den åpen kan man sette opp brannmur regler sånn at bare godkjente IP adresser kan nå den eller bruk av VPN.

Copyright © NYX Offensive Security

Sårbarhet-18
Kritisk: Cross-Site Request Forgery

Beskrivelse

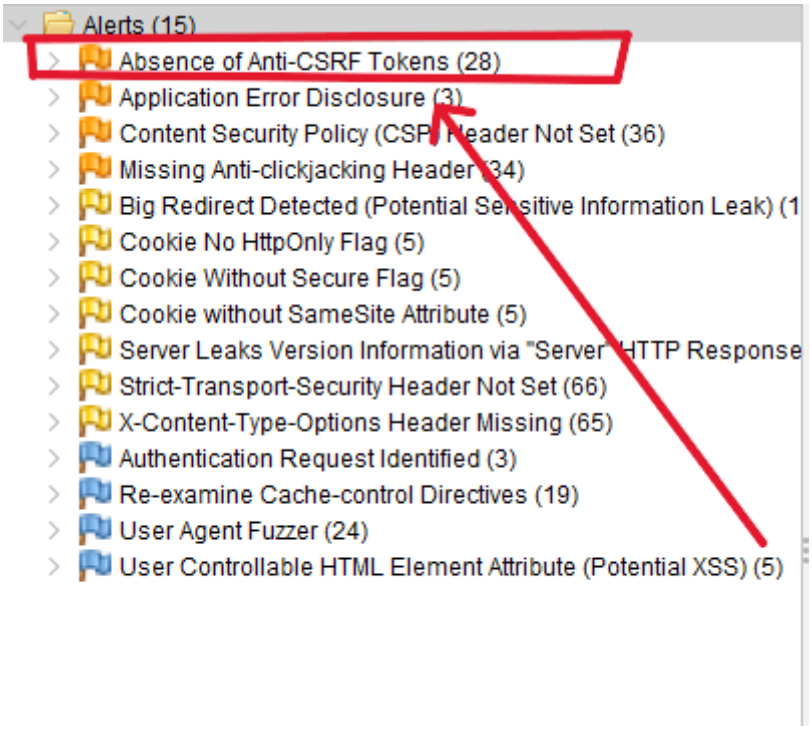
Zap skanningen viser til mangel på CSRF tokens på samtlige endepunkter. Cross-Site Request Forgery er når en angriper lurer en bruker til for eksempel å gå over til en annen nettside som angriperen kontrollerer. Når en bruker er på angriperens nettside kan da angriper utføre på vegne av bruker en handling som å slette konto eller publisere en kommentar på brukerens brukerkonto på Boris Lockpicks. Dette skjer uten at bruker er klar over dette og uten brukerens samtykke.

Det aktuelle området

Port: 80

PoC /Bilde og beskrivelse

Zap resultatet viser at Webapplikasjonen mangler CSRF token



Copyright © NYX Offensive Security

Ved undersøke hvordan POST requesten ser ut i første omgang kan jeg ta de verdiene som er markert på bilde og lage en enkel HTML kode som kan etterligne en angriper sin side.

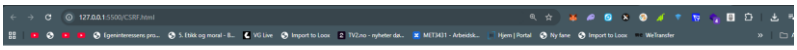
```
POST /guestbook.php HTTP/2
Host: 192.168.33.133
Content-Length: 33
Cache-Control: max-age=0
Sec-Ch-Ua: "Not_A Brand";v="99", "Chromium";v="142"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: nb-NO,nb;q=0.9
Origin: https://192.168.33.133
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9
/webp,image/apng,*/*;q=0.8,application/signed-exchang
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://192.168.33.133/guestbook.php
Accept-Encoding: gzip, deflate, br
Priority: u=0, i

name=TEST&comment=CSRFTEST&submit=Submit
```

Bildet under viser verdiene som er tatt fra burp suite over til VScode for å lage nettsiden

```
<!DOCTYPE html>
<html>
<body>
    <h1>CSRF Sårbarhet Når en bruker trykker på denne linken og er på den siden så vil de
<form id="csrfForm" action="https://192.168.33.133/guestbook.php" method="POST">
    <input type="hidden" name="name" value="CSRFTEST">
    <input type="hidden" name="comment" value="CSRF">
    <input type="hidden" name="submit" value="Submit">
</form>
<script>
    document.getElementById("csrfForm").submit();
</script>
</body>
</html>
```

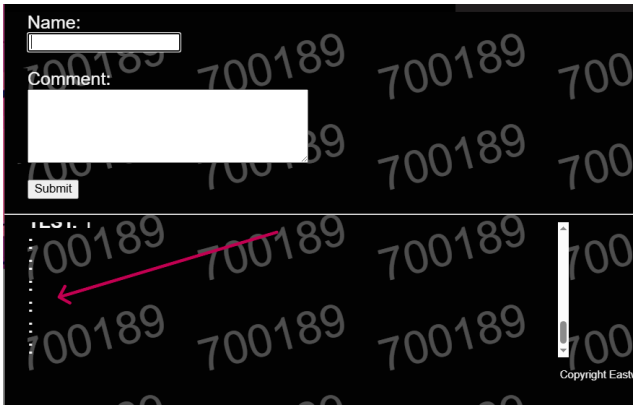
Bildet under viser angriperens sin side der en bruker har trykket på linken, det som skjer er at nettsiden til angriperen har lagt inn en kommentar på Boris lockpicks uten at brukeren vet dette.



CSRF Sårbarhet Når en bruker trykker på denne linken og er på den siden så vil de gjøre et uautorisert handling på BORIS Lockpick

På bildet under så skjedde det noe feil og har med hvordan serveren behandler teksten min, så kommentaren til brukeren som trykket på linken ble publisert men bare kolon tegnet kom opp. Men igjen så viser det at webapplikasjonen er sårbar for CSRF.

Copyright © NYX Offensive Security



Anbefalinger

- Bør bli implementert CSRF beskyttelse på alle endepunkter som har POST request til webserver.
- CSRF token som generer unik streng, gjør det umulig for angriper å sende uten å ha samme token.

Copyright © NYX Offensive Security

Sårbarhet-19
Medium: httponly flag er ikke satt

Beskrivelse

Cookie brukes til å identifisere brukeren når de er logget inn. Ved å få tilgang til denne vil en angriper enkelt kunne bruke session ID-en for å få tilgang til brukerkontoen. Det krever at angriperen klarer å injisere skadelig kode i offerets nettleser. Det er en stor fordel for angriperen dersom det finnes XSS på nettsiden, fordi det gjør det lettere å injisere skadelig JavaScript. ZAP skanningen avdekket at HttpOnly-flagget ikke var satt. Dette betyr at session cookien da er tilgjengelig for JavaScript ved å lese document.cookie.

Det aktuelle området

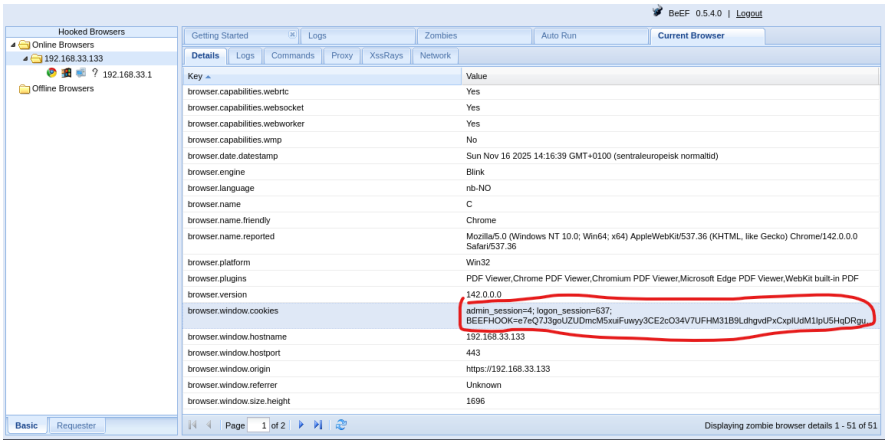
/tellfriend.php

PoC /Bilde og beskrivelse

Bildet viser ZAP skanning som advarer om at det ikke er HttpOnly flag



Ved en tidligere sårbarhet tok jeg bruk i Beef for å bevise at XSS funker, siden httponly flag er ikke aktivert så kan jeg vise til at man også fikk tak i session coockie fra nettleseren. Merk at dette funker bare når XSS sårbarhet finnes.



Copyright © NYX Offensive Security



Anbefalinger

- Det bør bli satt in HttpOnly flag

Copyright © NYX Offensive Security

Sårbarhet-20
Medium: Svak RSA nøkkel

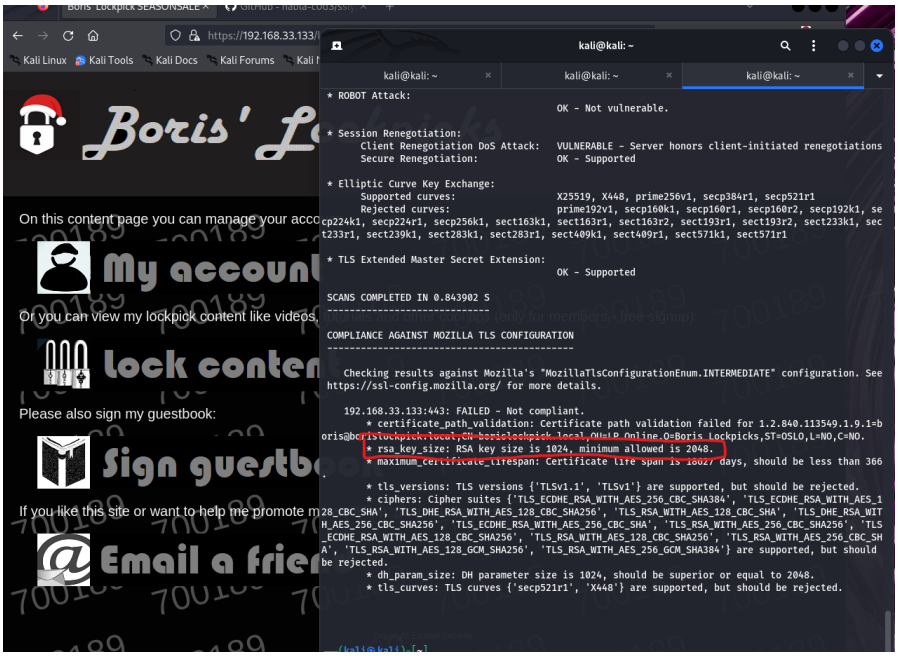
Beskrivelse

Etter en sslyze skanning så viste skanningen at det blir brukt en svakere **RSA** nøkkel som er på 1024 noe som ikke er tillatt hos flere nettlesere og egnes ikke som en sikker nøkkel for krypteringen. Det står også på skanningen at det minste tillatte nøkkel lengde er 2048 noe NIST heller ikke vil anbefale og forventes at dette blir byttet ut innen 2035. Problemet med 1024 er at en aktør med sterkere resurser kan knekke 1024 og dermed utføre Man-In-The-Middle angrep.

Det aktuelle området

Sårbarheten ligger på port 443 der kjøres HTTPS som skal sørge for at kommunikasjonen mellom server og klienten være sikkert med kryptering.

PoC /Bilde og beskrivelse



Copyright © NYX Offensive Security



Anbefalinger

- Bruk av minste tillatte nøkkel som lengde er 2048

Copyright © NYX Offensive Security

Sårbarhet-21
Medium: Eldre TLS versjon

Beskrivelse

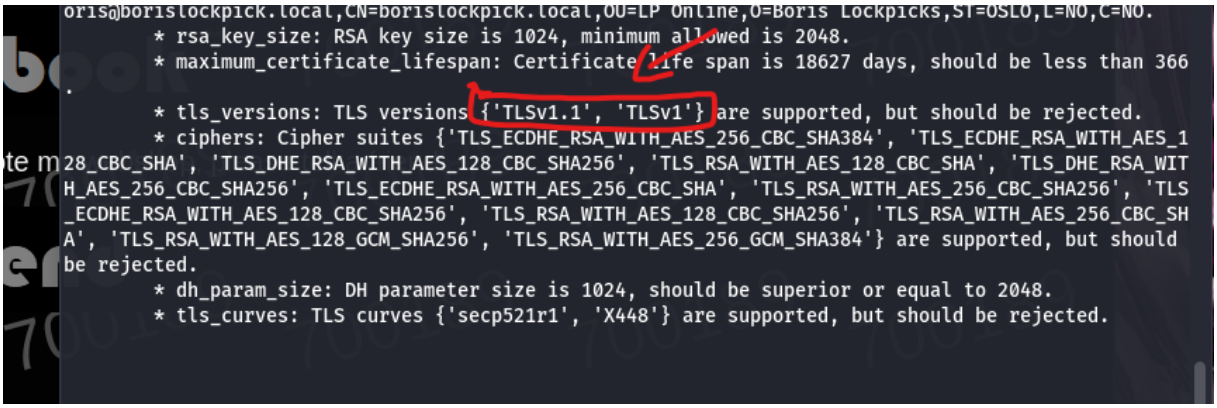
Det blir brukt eldre TLS versjon, dette er en eldre protokoll som er nå per dags dato en usikker protokoll å bruke. Konskevene kan være at man lettere kan omgå sikkerheten til den gamle protokollen og da kunne utføre en man-in-the middle angrep som betyr at angriper kan snoke på trafikken mellom brukeren og serveren.

Det aktuelle området

TLS protokollen

PoC /Bilde og beskrivelse

Bildet under viser en SSL skann som viser TLS protokollen denne webserveren bruker.



Anbefalinger

- Det anbefales at man går over til TLS 1.2 eller 1.3 som regnes som en mer sikrere protokoll

Referanser

For mer detaljer se her *anbefaling av TLS protokollen fra NIST*

https://csrc.nist.gov/pubs/sp/800/52/r2/final

Copyright © NYX Offensive Security

Sårbarhet-22
Medium: Sårbar versjon av OpenSSH 7.9p1

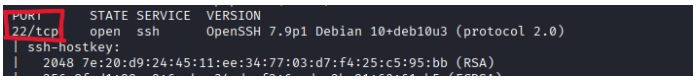
Beskrivelse

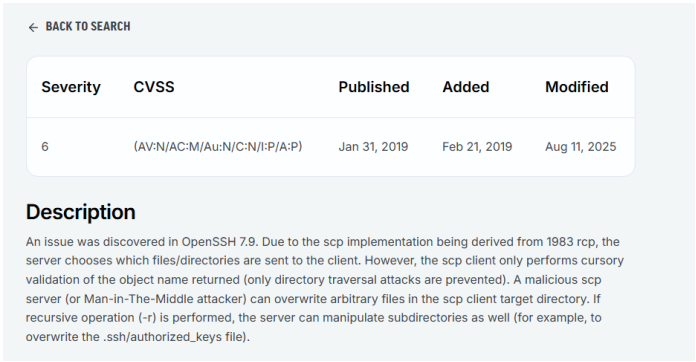
Nmap Skanningen viser til hvilken versjon port 22 kjører på og det viser seg at den kjører en eldre versjon av OpenSSH som ikke har blitt oppdatert på en god stund. Denne versjonen har med seg en rekke andre sårbarheter som finnes og har klare script altså exploit man kan bruke mot OpenSSH. Et eksempel på en sårbarhet kan da være CVE-2019-6111 som har en medium sårbarhets risiko og det også mye av grunnen til at denne versjonen har en medium sårbarhet fordi det ikke er oppdaget en kritisk sårbarhet foreløpig. CVE-2019-6111 er en sårbarhet der bruker kan bli lurt til å overskrive filer når man kopierer filer fra en server som ikke er trygg.

Det aktuelle området

Port 22

PoC /Bilde og beskrivelse





Anbefalinger

- Full Oppdatering av OpenSSH

Referanser

For mer detaljer se her

https://www.rapid7.com/db/vulnerabilities/openbsd-openssh-cve-2019-6111/

Copyright © NYX Offensive Security

Sårbarhet-23
Lav: Reflektert Cross-Site-scripting på Registrerings skjema

Beskrivelse

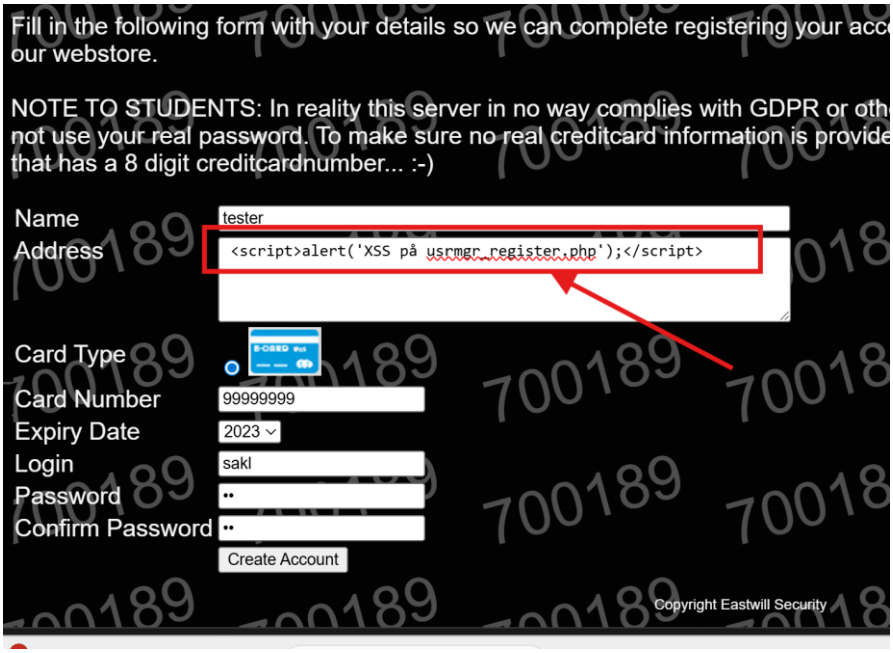
På registrerings skjema så foreligger det reflektert Cross-Site-Scripting-sårbarhet på input feltene. Denne sårbarheten får en lav risiko fordi man ikke kan utføre et direkte angrep på en bruker fordi man blir direkte sendt til SQL Error siden retter man har trykket på ok.

Det aktuelle området

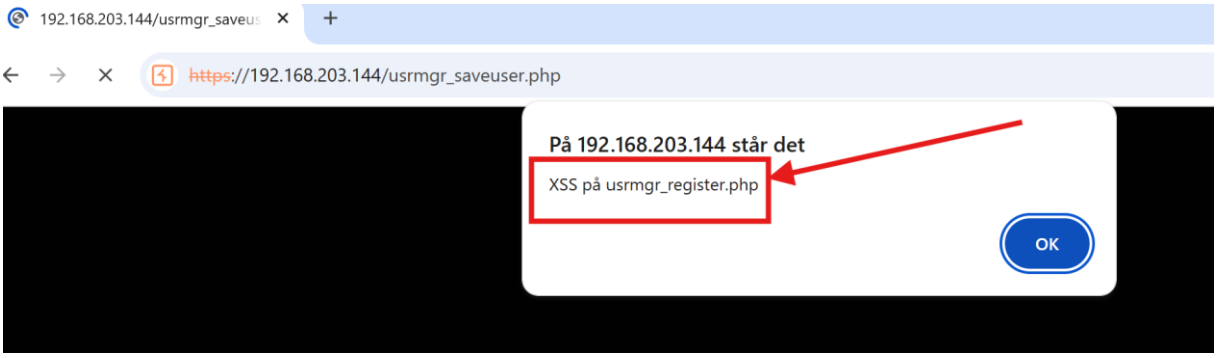
Port 80: Det aktuelle området gjelder på registrering skjemaet for brukere som skal registrere seg.

PoC /Bilde og beskrivelse

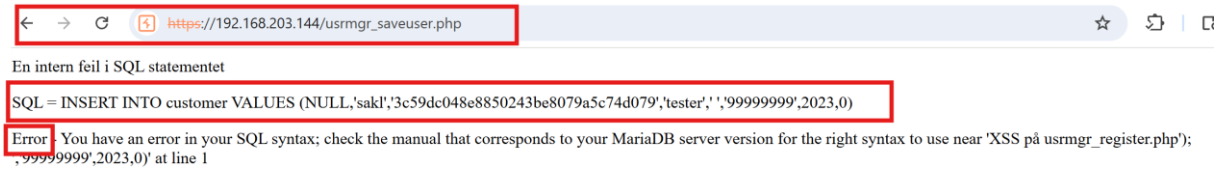
Når jeg hadde lagt inn script koden på adresse feltet så var neste steg å trykke på «Create Account»



Copyright © NYX Offensive Security



Etter man har trykket på ok så blir sendt videre til en SQL error side som også indikerer til en SQL-sårbarhet



Anbefalinger

- Det finnes en sanitserings funksjon på kildekoden bare den ikke blir brukt på adressefeltet. Det anbefales at det blir brukt på alle brukerinputene.

Copyright © NYX Offensive Security

Sårbarhet-24
Lav: Clickjacking

Beskrivelse

Ved å utføre en nikto scanning så avdekket denne skanningen for en clickjacking sårbarhet, Clickjacking vil si at en angriper kan sette opp sin egen nettside og legge Boris lockpicks sin url på HTML koden til angriperen sin nettside. Clickjacking kan brukes til å lure en bruker til å utføre en handling ved å gjøre boris lock siden på denne rammen usynlig så kan angriperen erstatte denne ved å legge til en knapp som kan få brukeren til å klippe denne knappen. Når brukeren klikker på denne knappen kan dette føre til at en bruker gjør en handling på Borislock pick sin webapplikasjon som ikke var ment å skje.

Det aktuelle området

Port: 80

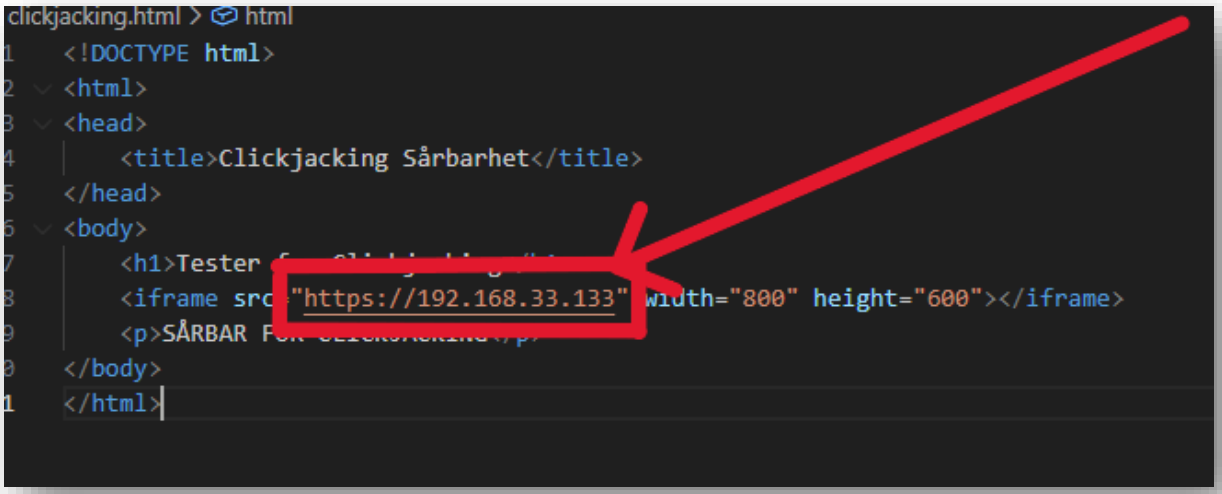
PoC /Bilde og beskrivelse

Bildet under viser at det er mangel på anti-clickjacking x-Frame-options header

```
┌──(kali㉿kali)-[~]
└─$ nikto -h https://192.168.33.133
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          192.168.33.133
+ Target Hostname:    192.168.33.133
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject:  /C=NO/L=NO/ST=OSLO/O=Boris Lockpicks/OU=LP Online/CN=borislock
pick.local/emailAddress=boris@borislockpick.local
                   Ciphers:  TLS_AES_256_GCM_SHA384
                   Issuer:   /C=NO/L=NO/ST=OSLO/O=Boris Lockpicks/OU=LP Online/CN=borislock
pick.local/emailAddress=boris@borislockpick.local
+ Start Time:         2025-11-17 17:35:58 (GMT-5)
---------------------------------------------------------------------------
+ Server: Abyss/2.16.9.1-X1-Linux AbyssLib/2.16.9.1
+ /: IP address found in the 'server' header. The IP is "2.16.9.1". See: https://portswigge
r.net/kb/issues/00600300_private-ip-addresses-disclosed
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mo
zilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
```


Copyright © NYX Offensive Security

For å bekrefte at dette funker lagde jeg en html-side og deretter satt inn URL til webapplikasjonen inn på koden



Når man går inn på html siden så kan vi se at webapplikasjonen til Boris lockpicks som bekrefter at clickjacking er mulig.



Copyright © NYX Offensive Security



Anbefalinger

- Det bør implementeres X-Frame-Options for å unngå at siden blir lastet opp hos andre nettsider.

Referanser

For mer detaljer se her

https://developer.mozilla.org/en-US/docs/Web/Security/Attacks/Clickjacking

Copyright © NYX Offensive Security

Sårbarhet-25
Lav: skjult fil phpinfo.php

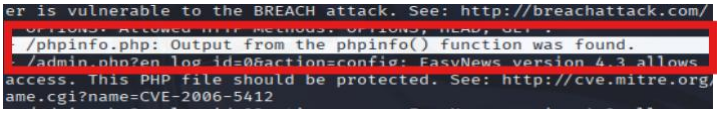
Beskrivelse

Nikto skanningen viser til en skjult php fil som avslører PHP versjonen som den kjører, dette avslører sårbarhetene den kan være utsatt for.

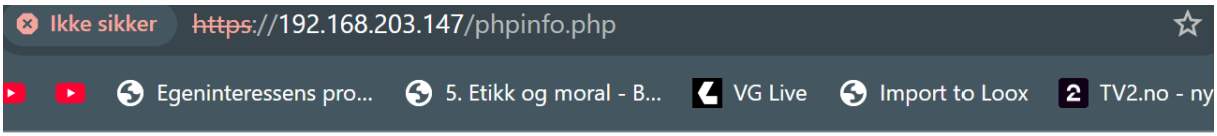
Det aktuelle området

/Phpinfo.php

PoC /Bilde og beskrivelse



Bildet under bekrefter at phpinfo vises.



PHP Version 7.3.31-1~deb10u5

System	Linux osboxes 4.19.0-5-amd64 #1 SMP Debian 4.19.3
Build Date	Sep 4 2023 21:49:25
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/7.3/cgi
Loaded Configuration File	/etc/php/7.3/cgi/php.ini
Scan this dir for additional .ini files	/etc/php/7.3/cgi/conf.d
Additional .ini files parsed	/etc/php/7.3/cgi/conf.d/10-mysqlnd.ini, /etc/php/7.3/cgi/

Anbefalinger

- Det anbefales at filen fjernes eller lukkes

Copyright © NYX Offensive Security

Sårbarhet-26
Informasjon: Server viser versjon nummer den kjører

Beskrivelse

Under en Full NMAP undersøkelse så avslører serveren hva slags versjon den kjører. Dette kan være til fordel for angripere som prøver å finne så som mulig av informasjon som de kan bruke til et eventuelt angrep på webapplikasjonen.

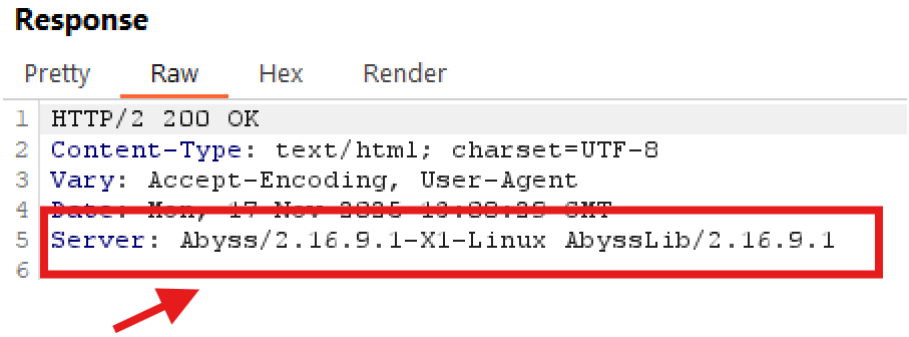
Det aktuelle området

Port: 80

Response headere

PoC /Bilde og beskrivelse

Ved å se på responsen til Burp suite så viser serveren på headeren hva slags versjon den kjører



Anbefalinger

- Skjule informasjon av versjon nummer som kjøres på webserver

Copyright © NYX Offensive Security

Sårbarhet-27
Informasjon: Mulighet for Command injection

Beskrivelse

På koden til webapplikasjonen så er det en kodefunksjon som kan muliggjøre for Command Injection, Command injection er en sårbarhet der en angriper kan sende uautoriserte kommandoer til maskinen som kjører webserveren. Det er altså direkte tilgang til maskinen gjennom Webapplikasjonen.

Det aktuelle området

/sendemail.php

PoC /Bilde og beskrivelse

På Meesage feltet blir bruker feltet lagret først som variabel og satt inn i en annen variabel som CMD_WIN

```
$from = $_POST["from"];
$subject = $_POST["subject"];
$message = $_POST["message"].$_POST["endtxt"];
$cmd_linx = "./backend/sendemail_linux \"$email\" \"$to\" \"$subject\" \"$message\"";
$cmd_osx_arm = "./backend/sendemail_osx_arm \"$email\" \"$to\" \"$subject\" \"$message\"";
$cmd_win = "backend\\sendemail_win.exe \"$email\" \"$to\" \"$subject\" \"$message\"";
$uname = php_uname('m');
```

Videre blir «CMD_WIN» satt inn i exec() funksjon som

```
if (strtoupper(substr(PHP_OS, 0, 3)) === 'WIN') {
    // Windows operating system, 32 bit application will run on both x86 and x64:
    exec($cmd_win, $output, $return_value);
} else if (strtoupper(substr(PHP_OS, 0, 6)) === 'DARWIN' && strpos($uname, 'arm') !==
    // Darwin is the codename for MacOS, and we have an ARM compile for X1 and X2:
    exec($cmd_osx_arm, $output, $return_value);
} else {
    // Otherwise will attempt the linux executable, will fail if x86 MacOS:
    exec($cmd_linx, $output, $return_value);
}
```

Anbefalinger

- Bruken av exec() må være forsiktig brukt fordi det gir tilgang til maskinen gjennom kommandoer
- Rense for input fra inputfelt

Copyright © NYX Offensive Security



Konklusjon

For å konkludere funnene som har blitt dokumentert så anbefaler NYX OFFENSIVE at det blir gjort umiddelbare endringer på de kritiske funnene først fordi det er disse som utgjør en stor risiko for foretaket. Mange av disse sårbarhetene utgjør også brudd på den norske Personvernloven fordi data som har blitt funnet på systemet er lett tilgjengelig for angripere.

Referanser

Se mer om Personopplysningsloven

https://lovdata.no/dokument/NL/lov/2018-06-15-38



SLUTT

Copyright © NYX Offensive Security